Protecting federal information and systems

What Congress required, what OMB directed, and how NIST turned those duties into standards and guidance. A source-led history from 2000 to 2026, with the earlier foundations.

Research checked 25 October 2026 · 41 milestones · 80 direct quotations
Legal and publication editions are stated separately. Coverage and limits

Start in 2000 Current responsibilities Complete print edition

Two objects of protection. Duties that overlap.

The law tells agencies to protect their information and their systems. It does not make ownership of equipment the only test. Later policy explains what agencies must do when another organization handles the information or provides the system.

FISMA's shared rule: protection commensurate with risk and harm

Information

Collected or maintained **by or on behalf of** the agency.

The duty can follow information outside the agency's own system.

Information systems

Used or operated by the agency, or by another organization on its behalf.

The duty includes the system, its controls, and the agency's oversight.

Read the exact statutory clauses · The same wording appeared in 2002.

Three points prevent common misreadings:

1. **Risk assessment and compliance go together.** FISMA requires both. A duty to understand risk is not an alternative to applicable standards and policy.
2. **"Outside our boundary" does not mean "outside our responsibility."** NIST distinguishes external services from the system that uses them while preserving the agency's information and risk duties.
3. **The nonfederal-system path has conditions.** The CUI rule and SP 800-171 provide an explicit, narrower requirements set. They do not cover every external service or every kind of federal information.

FISMA's implementation duties · NIST's external-boundary distinction · The CUI rule's limits

Each milestone separates this report's explanation from the source quotation. Quotations retain the original wording; spacing and line-end hyphenation are normalized. Footnote numbers remain where they appear in extracted text. Follow "Read original" for the surrounding text and footnotes. Historical text is not labeled as current merely because it is quoted here.

How the authorities connect

There is more than one path. Congress directed NIST and Commerce as well as OMB. Later law also incorporated definitions from an existing circular. The labels below describe an explicit relationship in the cited text; chronological order alone is not evidence of one.

PRA → A-130

Implements. OMB says it issued A-130 to fulfill the PRA responsibilities. Read the connecting words

FISMA → NIST / Commerce

Requires. Congress assigns standards work and directs submission to Commerce. Read the connecting words

FISMA → FIPS 199

Implements. FIPS 199 identifies the first statutory task it addresses. Read the connecting words

FISMA → SP 800-60

Implements. The mapping guide identifies the second task. Read the connecting words

FIPS 200 → SP 800-53

Incorporates. The standard requires selection using the control catalog. Read the connecting words

A-130 → SP 800-37

Implements. NIST attributes the authorization requirement to A-130. Read the connecting words

SP 800-53 → SP 800-37

Cites. The 2010 RMF cites the catalog's external-environment appendix. Read the connecting words

CUI rule → SP 800-171

Incorporates. The rule directs use of 800-171 for qualifying nonfederal CUI confidentiality. Read the connecting words

SP 800-53 → SP 800-171

Derived from. NIST describes tailoring requirements from the federal standards and guidelines. Read the connecting words

FedRAMP Act → A-130 definitions

Incorporates. Congress imports two definitions from the circular. Read the connecting words

FedRAMP Act → OMB scope policy

Requires. Congress directs OMB to specify program scope. Read the connecting words

A-130 → SP 800-18 Revision 2

Implements. The planning guide identifies A-130's system-plan requirement. Read the connecting words

Records guidance ↔ cloud security

Related context. Records duties coexist with security duties; this is not a claimed chain of authority. Read the connecting words

Before 2000

The information duty came first

PRA: give OMB responsibility for information policy

1980 **Law**

The Paperwork Reduction Act gave OMB an information-management role that included security. The quoted duty belongs to OMB's Director. Its object is information collected or maintained by or on behalf of agencies.

Where it came from

Congress assigned the policy function in the PRA. OMB later identified the PRA as the authority behind A-130.

What changed—or stayed

This is an early information-based duty. It does not depend on the government owning the equipment that holds the information.

Law

Paperwork Reduction Act of 1980

§2, former 44 USC 3504(f)(1); 94 Stat. 2816 · 1980-12-11

developing and implementing policies, principles, standards, and guidelines on information disclosure and confidentiality, and on safeguarding the security of information collected or maintained by or on behalf of agencies;

Read original · PDF 5 Source details Link to quote

The Computer Security Act includes processing services

1988 **Law**

The Computer Security Act of 1987 was enacted on January 8, 1988. Its definition joined system operation to processing information for a federal function. It also assigned standards work to the National Bureau of Standards, later renamed NIST.

Where it came from

Congress directed the Bureau to develop standards and send them to Commerce for promulgation. The Act also required agency security plans and training (§§5–6).

What changed—or stayed

Private operation was already within the statutory definition in specified circumstances. "On behalf of" did not start with cloud computing or FISMA.

Law

Computer Security Act of 1987, P.L. 100-235

§3, NBS Act §20(d)(2)(A); 101 Stat. 1726 · 1988-01-08

means a computer system operated by a Federal agency or by a contractor of a Federal agency or other organization that processes information (using a computer system) on behalf of the Federal Government to accomplish a Federal function;

Read original · PDF 3 Source details Link to quote

Law

Computer Security Act of 1987, P.L. 100-235

§3, NBS Act §20(a)(4); 101 Stat. 1725 · 1988-01-08

submit standards and guidelines developed pursuant to paragraphs (2) and (3) of this subsection, along with recommendations as to the extent to which these should be made compulsory and binding, to the Secretary of Commerce for promulgation under section 111(d) of the Federal Property and Administrative Services Act of 1949;

Read original · PDF 2 Source details Link to quote

A-130 explains its PRA roots—and the role of agreements

1993 **OMB policy**

OMB's 1993 revision focused on information management, dissemination, and records. Its explanatory appendix cautioned that agencies' information responsibilities were not automatically identical to those of grantees and contractors.

Where it came from

The notice expressly says OMB issued the original 1985 circular to fulfill its PRA responsibilities. The second quotation is OMB's analysis of "Government Information," not a later FISMA exemption.

What changed—or stayed

Agency duties could be carried into grants and contracts. Read this historically: later security statutes and policies added requirements, and the 2016 circular replaced this edition.

OMB policy

A-130: Transmittal 1

1993 notice, Background (opening explanation) · 1993-06-25

The Paperwork Reduction Act (PRA) (44 U.S.C. Chapter 35) assigns the Director of OMB responsibility for maintaining a comprehensive set of information resources management (IRM) policies and for promoting the application of information technology to improve the use and dissemination of information by Federal agencies. To fulfill these responsibilities, OMB issued Circular No. A-130, Management of Federal Information Resources (50 FR 52730; December 24, 1985), which provided a policy framework for the management of Federal information resources.

Read original Source details Link to quote

OMB policy

A-130: Transmittal 1

Appendix IV §3, analysis of §6: Government Information · 1993-06-25

Thus the information responsibilities of grantees and contractors are not identical to those of Federal agencies except to the extent that the agencies make them so in the underlying grants or contracts.

Read original Source details Link to quote

PRA: agencies must protect information “by or for” them

1995 Law

The 1995 PRA restated agency responsibilities. Section 3506(g) combined compliance, accountability, and protection proportionate to risk. It expressly referred to the Computer Security Act.

Where it came from

This is Congress’s agency-level duty, separate from the Director’s policy role quoted above.

What changed—or stayed

Notice the different phrases: paragraph (1) says “by or for the agency”; paragraph (3) says “by or on behalf of an agency.” Both concern information. Later amendments changed the cross-references; this is the 1995 enactment.

Law

Paperwork Reduction Act of 1995

§2, 44 USC 3506(g); 109 Stat. 175 · 1995-05-22

“(g) With respect to privacy and security, each agency shall—

“(1) implement and enforce applicable policies, procedures, standards, and guidelines on privacy, confidentiality, security, disclosure and sharing of information collected or maintained by or for the agency;

“(2) assume responsibility and accountability for compliance with and coordinated management of sections 552 and 552a of title 5, the Computer Security Act of 1987 (40 U.S.C. 759 note), and related information management laws; and

“(3) consistent with the Computer Security Act of 1987 (40 U.S.C. 759 note), identify and afford security protections commensurate with the risk and magnitude of the harm resulting from the loss, misuse, or unauthorized access to or modification of information collected or maintained by or on behalf of an agency.

Read original · PDF 13 Source details Link to quote

A-130 requires risk-based protection, not one method of analysis

1996 **OMB policy**

A-130 §8(a)(1)(g) directed agencies to protect government information in proportion to risk. The revised security appendix also addressed system plans, controls, reviews, and authorization.

Where it came from

In its response to public comments, OMB linked risk-based controls to the Computer Security Act. Some commenters opposed removing formal risk analyses; others found them too costly.

What changed—or stayed

OMB kept risk assessment essential while declining to require a formal risk analysis for every system. Risk-based judgment concerned how to meet the duty; it did not remove the duty.

OMB policy

A-130: Transmittal 3

§8(a)(1)(g) · 1996-02-08

Protect government information commensurate with the risk and magnitude of harm that could result from the loss, misuse, or unauthorized access to or modification of such information;

Read original Source details Link to quote

OMB circular

A-130 Transmittal 3: Federal Register final notice

61 FR 6430, response to comment 5; explanation, not a separate rule · 1996-02-20

We agree that security measures must be risk-based. The Computer Security Act requires that security controls be commensurate with the risk and magnitude of harm that could occur. Implicit in that approach is a need to assess the risk to each system. However, given the complexity and detail such formal analyses often entail, a formal risk analysis is not appropriate for every system. Therefore, the Appendix does not require that a formal risk analysis be performed. At the same time, risk assessment is an essential element in ensuring adequate security.

Read original · PDF 3 Source details Link to quote

2000–2004

Two duties, then a standards program

GISRA makes security an agency-wide program

2000 **Law**

The Government Information Security Reform provisions required protections for information and systems supporting agency operations. They also required an agency-wide program, periodic assessments, testing, and independent evaluation.

Where it came from

Congress enacted these provisions in the FY2001 defense authorization law, Public Law 106–398. Former 44 USC 3534 supplied the agency duties; §3535 supplied independent evaluations.

What changed—or stayed

The law quoted here uses "information collected or maintained by or for the agency." It predates the two separately numbered objects of protection in FISMA 2002. The temporary GISRA framework was followed by FISMA.

Law

GISRA in P.L. 106-398

§1061, former 44 USC 3534(a)(1); 114 Stat. 1654A–268 · 2000-10-30

"(A) adequately ensuring the integrity, confidentiality, authenticity, availability, and nonrepudiation of information and information systems supporting agency operations and assets;

"(B) developing and implementing information security policies, procedures, and control techniques sufficient to afford security protections commensurate with the risk and magnitude of the harm resulting from unauthorized disclosure, disruption, modification, or destruction of information collected or maintained by or for the agency; and

"(C) ensuring that the agency's information security plan is practiced throughout the life cycle of each agency system;

Read original · PDF 270 Source details Link to quote

The 2000 A-130 revision chiefly implements Clinger–Cohen

2000 **OMB policy**

The 2000 revision addressed IT investment and management. Its existing security appendix also explained how agencies should decide whether to interconnect systems.

Where it came from

The final notice expressly identifies Clinger–Cohen as the reason for this revision. Its timing near GISRA does not establish that GISRA caused the revision.

What changed—or stayed

Information moving between systems already called for safeguards and a management decision about risk. This is a connection decision, not a statement that every connected system becomes an agency system.

OMB circular

Transmittal 4 final Federal Register notice

65 FR 77677, summary; November 28 revision announced December 12 · 2000-12-12

The Office of Management and Budget issues a revision to Circular No. A–130, "Management of Federal Information Resources," to implement provisions of the Clinger-Cohen Act (also known as "Information Technology Management Reform Act of 1996") and for other purposes.

Read original · PDF 1 Source details Link to quote

OMB policy

A-130 (2000), Appendix III

Appendix III, Part B, General Support Systems, Security Plan / Interconnection · 2000-11-28

The management decision to interconnect should be based on the availability and use of technical and non-technical safeguards and consistent with the acceptable level of risk defined in the system rules.

Read original Source details Link to quote

FISMA writes the two duties side by side

2002 **Law**

The December 2002 Federal Information Security Management Act required agency heads to protect two things: information collected or maintained by or on behalf of the agency, and systems used or operated by the agency or for it. The same risk standard governs both.

Where it came from

Title III of the E-Government Act, Public Law 107–347, enacted former 44 USC 3544. November's Homeland Security Act also contained FISMA provisions; this report quotes the December enactment that supplied this framework.

What changed—or stayed

The agency-wide program expressly includes information and systems provided or managed by another agency, a contractor, or another source. The statute does not say "only the components the agency directly controls." Nor does it define every external service as a federal system.

Law

E-Government Act / FISMA 2002

§301, former 44 USC 3544(a)(1)(A); 116 Stat. 2949 · 2002-12-17

“(A) providing information security protections commensurate with the risk and magnitude of the harm resulting from unauthorized access, use, disclosure, disruption, modification, or destruction of—

“(i) information collected or maintained by or on behalf of the agency; and

“(ii) information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency;

Read original · PDF 51 Source details Link to quote

Law

E-Government Act / FISMA 2002

§301, former 44 USC 3544(b); 116 Stat. 2950 · 2002-12-17

Each agency shall develop, document, and implement an agencywide information security program, approved by the Director under section 3543(a)(5), to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source, that includes —

Read original · PDF 52 Source details Link to quote

Congress sends work directly to NIST and Commerce

2002 Law

FISMA did more than tell OMB to issue policy. It directly assigned NIST standards and guideline work and set deadlines for categorization standards, mapping guidance, and minimum requirements.

Where it came from

FISMA §303 amended the NIST Act. Section 302 amended 40 USC 11331 on Commerce’s prescription of standards. NIST develops; Commerce approves binding standards under the statutory process.

What changed—or stayed

This is why the history is not simply law → OMB → NIST. There is also a direct law → NIST/Commerce path. FIPS 199, SP 800-60, and FIPS 200 identify themselves as responses to the assigned tasks.

Law

E-Government Act / FISMA 2002

§303, NIST Act §20(a)(2)–(3); 116 Stat. 2957 · 2002-12-17

“(2) develop standards and guidelines, including minimum requirements, for information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency, other than national security systems (as defined in section 3542(b)(2) of title 44, United

States Code); and

“(3) develop standards and guidelines, including minimum requirements, for providing adequate information security for all agency operations and assets, but such standards and guidelines shall not apply to national security systems.

Read original · PDF 59 Source details Link to quote

Law

E-Government Act / FISMA 2002

§303, NIST Act §20(b)(1)(A)–(B); 116 Stat. 2957; minimum requirements follow in (C) · 2002-12-17

“(1)(A) standards to be used by all agencies to categorize all information and information systems collected or maintained by or on behalf of each agency based on the objectives of providing appropriate levels of information security according to a range of risk levels;

“(B) guidelines recommending the types of information and information systems to be included in each such category; and

Read original · PDF 59 Source details Link to quote

Law

E-Government Act / FISMA 2002

§303, NIST Act §20(c)(3)–(4); 116 Stat. 2958 · 2002-12-17

“(3) submit to the Secretary of Commerce for promulgation under section 11331 of title 40, United States Code—

“(A) standards, as required under subsection (b)(1)(A), no later than 12 months after the date of the enactment of this section; and

“(B) minimum information security requirements for each category, as required under subsection (b)(1)(C), no later than 36 months after the date of the enactment of this section;

“(4) issue guidelines as required under subsection (b)(1)(B), no later than 18 months after the date of the enactment of this section;

Read original · PDF 60 Source details Link to quote

Law

E-Government Act / FISMA 2002

§302, 40 USC 11331(b)(2); 116 Stat. 2956 · 2002-12-17

“(2) REQUIRED MANDATORY STANDARDS.—(A) Standards prescribed under subsection (a)(1) shall include information security standards that—

“(i) provide minimum information security requirements as determined under section 20(b) of the National Institute of Standards and Technology Act (15 U.S.C. 278g– 3(b)); and

“(ii) are otherwise necessary to improve the security of Federal information and information systems.

“(B) Information security standards described in subparagraph (A) shall be compulsory and binding.

Read original · PDF 58 Source details Link to quote

OMB explains incidental equipment and NIST’s role

2003–2004 **OMB policy**

OMB’s first FISMA reporting instructions already said an agency remained responsible for federal information used on incidentally acquired equipment. In 2004, OMB also distinguished mandatory FIPS from NIST guidance.

Where it came from

M-03-19 and M-04-25 implemented FISMA reporting and interpretation. They referred agencies to A-130 Appendix III for appropriate controls.

What changed—or stayed

An equipment exclusion in procurement law did not erase information-security responsibility. The 2004 answer also cautions against treating every sentence in a NIST publication as if it had the same status as a FIPS requirement.

OMB memorandum

M-03-19, Reporting Instructions for the Federal Information Security Management Act and Updated Guidance on Quarterly IT Security Reporting

§I.A, p. 5 · 2003-08-06

Therefore, when Federal information is used within incidentally acquired equipment, the agency is responsible for ensuring that FISMA requirements are met.

Read original · PDF 5 Source details Link to quote

OMB memorandum

M-04-25, FY 2004 Reporting Instructions for the Federal Information Security Management Act

§II.A, p. 5; historical reporting guidance · 2004-08-23

Is use of NIST publications required? Yes, for non-national security programs and systems, agencies must follow NIST standards and guidance. Federal Information Processing Standards (FIPS) must be implemented as written; the only flexibility exists within the standard itself. Special publications of the NIST 800 series and other NIST publications are guidance. As a general rule, use of NIST guidance is more flexible, provided agency implementation is consistent with the principles and processes outlined within the NIST guidance. However, from time to time, OMB policy will mandate stricter use of NIST guidance. For example, NIST Special Publication 800-26 is mandatory for use for agency annual systems reviews. Reviews and evaluations of agency IT

security programs and systems should consider adherence to standards and consistency with NIST guidance. Where flexibility exists, evaluations must consider unique operational environments and allow for a reasonable degree of discretion.

Read original · PDF 5 Source details Link to quote

FIPS 199: categorize information and systems

2004 **Mandatory standard**

FIPS 199 supplies low, moderate, and high impact categories for confidentiality, integrity, and availability. The impact of losing information helps determine the protection a system needs.

Where it came from

The standard explicitly identifies FISMA's first task: categorization. Its applicability section distinguishes information from federal information systems and states the classified-information and national-security-system exceptions.

What changed—or stayed

Categorization is a required input to decisions. It does not itself choose every control or decide whether an external system operates on an agency's behalf.

Mandatory standard

FIPS 199: Security Categorization

§1, printed p. 1 · 2004-02-01

FIPS Publication 199 addresses the first task cited—to develop standards for categorizing information and information systems. Security categorization standards for information and information systems provide a common framework and understanding for expressing security that, for the federal government, promotes: (i) effective management and oversight of information security programs, including the coordination of information security efforts throughout the civilian, national security, emergency preparedness, homeland security, and law enforcement communities; and (ii) consistent reporting to the Office of Management and Budget (OMB) and Congress on the adequacy and effectiveness of information security policies, procedures, and practices. Subsequent NIST standards and guidelines will address the second and third tasks cited.

Read original · PDF 5 Source details Link to quote

Mandatory standard

FIPS 199: Security Categorization

§2, printed p. 1 · 2004-02-01

These standards shall apply to: (i) all information within the federal government other than that information that has been determined pursuant to Executive Order 12958, as amended by Executive Order 13292, or any predecessor order, or by the Atomic Energy Act of 1954, as amended, to require protection against unauthorized disclosure and is marked to indicate its

classified status; and (ii) all federal information systems other than those information systems designated as national security systems as defined in 44 United States Code Section 3542(b)(2). Agency officials shall use the security categorizations described in FIPS Publication 199 whenever there is a federal requirement to provide such a categorization of information or information systems.

Read original · PDF 5 Source details Link to quote

SP 800-37: evidence for an authorization decision

2004 **NIST guidance**

The first SP 800-37 explained security certification and accreditation. Certification assessed controls; accreditation was a senior official's decision to authorize operation and accept the resulting risk.

Where it came from

The publication cites its FISMA responsibilities and says it is consistent with A-130 §8(b)(3). It expressly attributes the accreditation requirement to A-130 Appendix III.

What changed—or stayed

This connects statutory responsibility and OMB policy to a practical system-level decision. Risk acceptance follows evidence about controls; it is not permission to disregard applicable requirements.

NIST guidance

SP 800-37: Certification and Accreditation

Authority, p. ii · 2004-05-01

This document has been developed by the National Institute of Standards and Technology (NIST) in furtherance of its statutory responsibilities under the Federal Information Security Management Act (FISMA) of 2002, Public Law 107-347. NIST is responsible for developing standards and guidelines, including minimum requirements, for providing adequate information security for all agency operations and assets, but such standards and guidelines shall not apply to national security systems. This guideline is consistent with the requirements of the Office of Management and Budget (OMB) Circular A-130, Section 8b(3), Securing Agency Information Systems, as analyzed in A-130, Appendix IV: Analysis of Key Sections. Supplemental information is provided A-130, Appendix III.

Read original · PDF 4 Source details Link to quote

NIST guidance

SP 800-37: Certification and Accreditation

Executive summary, p. v; explicit A-130 Appendix III requirement · 2004-05-01

Security accreditation is the official management decision given by a senior agency official to authorize operation of an information system and to explicitly accept the risk to agency operations, agency assets, or individuals based on the implementation of an agreed-upon set of security controls. Required by OMB Circular A-130, Appendix III, security accreditation provides a form of quality control and challenges managers and technical staffs at all levels to implement the most effective security controls possible in an information system, given mission requirements, technical constraints, operational constraints, and cost/schedule constraints.

Read original · PDF 7 Source details Link to quote

SP 800-60: map information types to impact categories

2004 **NIST guidance**

The second FISMA task was guidance on which information and systems belong in each category. SP 800-60 provided a method and provisional impact levels for information types.

Where it came from

Its executive summary explicitly says it responds to the second task and assumes familiarity with FIPS 199.

What changed—or stayed

The information and the system are linked: the system's use, connectivity, and aggregate information content inform its category. The mapping is a starting point to review, not an automatic answer for every agency.

NIST guidance

SP 800-60 Vol. 1 — Guide for Mapping Types of Information and Information Systems to Security Categories

Volume I, executive summary, p. vii · 2004-06-10

In response to the second of these tasks, this guideline has been developed to assist Federal government agencies to categorize information and information systems. The guideline's objective is to facilitate provision of appropriate levels of information security according to a range of levels of impact or consequences that might result from the unauthorized disclosure, modification, or loss of availability of the information or information system. This guideline assumes that the user is familiar with Standards for Security Categorization of Federal Information and Information Systems (FIPS 199). The guideline and its appendixes: • Review the security categorization terms and definitions established by FIPS 199; • Recommend a security categorization process; • Describe a methodology for identifying types of Federal information and information systems; • Suggest provisional security impact levels for common information types; • Discuss information attributes that may result in variances from the provisional impact level assignment; and • Describe how to establish a system security categorization based on the system's use, connectivity, and aggregate information content.

Read original · PDF 8 Source details Link to quote

2005–2009

Controls, boundaries, and external services

SP 800-53: outsourced services have control obligations

2005 **NIST guidance**

The first SP 800-53 supplied a catalog and baselines of controls. SA-9 addressed outsourced information-system services and required the organization to monitor compliance.

Where it came from

This was part of NIST's FISMA standards-and-guidelines work. The following year, FIPS 200 expressly required control selection using SP 800-53.

What changed—or stayed

The original SA-9 guidance described the same control and documentation requirements as internal systems. That wording matters historically; later editions describe external services and trust in more detail.

NIST guidance

SP 800-53: Recommended Security Controls

SA-9, control and opening supplemental guidance; p. 92 · 2005-02-01

The organization ensures that third-party providers of information system services employ adequate security controls in accordance with applicable federal laws, directives, policies, regulations, standards, guidance, and established service level agreements. The organization monitors security control compliance. Supplemental Guidance: Third-party providers are subject to the same information system security policies and procedures of the supported organization, and must conform to the same security control and documentation requirements as would apply to the organization's internal systems.

Read original · PDF 100 Source details Link to quote

FIPS 200: use the impact category to select controls

2006 **Mandatory standard**

FIPS 200 established minimum security requirements. Agencies meet them through appropriately tailored SP 800-53 baselines, using the FIPS 199 categorization.

Where it came from

The standard's announcement identifies FISMA as its authority and Commerce as the approving authority. Section 4 explicitly connects FIPS 199 to SP 800-53; footnote 5 calls for the current SP 800-53, as amended.

What changed—or stayed

Risk assessment and tailoring are part of compliance. They do not turn minimum requirements into optional advice. FIPS 200's applicability covers federal information and federal systems, with stated exceptions; the standard does not declare every private system federal.

Mandatory standard

FIPS 200: Minimum Security Requirements

§4, printed p. 4; footnote 5 requires the current SP 800-53, as amended · 2006-03-09

Organizations must meet the minimum security requirements in this standard by selecting the appropriate security controls and assurance requirements as described in NIST Special Publication 800-53, Recommended Security Controls for Federal Information Systems.5 The process of selecting the appropriate security controls and assurance requirements for organizational information systems to achieve adequate security6 is a multifaceted, risk-based activity involving management and operational personnel within the organization. Security categorization of federal information and information systems, as required by FIPS Publication 199, is the first step in the risk management process.7 Subsequent to the security categorization process, organizations must select an appropriate set of security controls for their information systems that satisfy the minimum security requirements set forth in this standard. The selected set of security controls must include one of three, appropriately tailored8 security control baselines from NIST Special Publication 800-53 that are associated with the designated impact levels of the organizational information systems as determined during the security categorization process.

Read original · PDF 10 Source details Link to quote

SP 800-18 Revision 1: define the system being planned for

2006 **NIST guidance**

The system-security-plan guide tells agencies to categorize the system and its information before drawing boundaries and selecting controls. A boundary identifies the resources covered by the plan.

Where it came from

The revision connects system planning to FIPS 199 and the SP 800-53 baseline process.

What changed—or stayed

"Direct management control" is a guide for grouping resources. The text expressly allows intervening management. It is not a statutory test that excludes every resource an agency cannot administer directly.

NIST guidance

SP 800-18 Rev. 1: Security Plans

§2.1, printed p. 9; see footnote 10 on budgetary/programmatic/operational authority · 2006-02-01

The process of uniquely assigning information resources9 to an information system defines the security boundary for that system. Agencies have great flexibility in determining what constitutes an information system (i.e., major application or general support system). If a set of information

resources is identified as an information system, the resources should generally be under the same direct management control. Direct management control10 does not necessarily imply that there is no intervening management.

Read original · PDF 16 Source details Link to quote

SP 800-53 Revisions 1 and 2: outside the boundary still matters

2006–2007 **NIST guidance**

SA-9 changed from “Outsourced” to “External Information System Services.” Its explanation covered services used by a system but outside its accreditation boundary, including several forms of business relationship.

Where it came from

These are revisions of the control catalog used through FIPS 200. The two quotations below are from Revision 1 and Revision 2 respectively.

What changed—or stayed

The quoted passages are identical in the collected editions. The important distinction is between the authorization boundary and responsibility for risks arising from an external service. Being outside the boundary does not end that responsibility.

NIST guidance

SP 800-53 Rev. 1 — Recommended Security Controls for Federal Information Systems

SA-9 supplemental guidance, p. 120 · 2006-12-19

An external information system service is a service that is implemented outside of the accreditation boundary of the organizational information system (i.e., a service that is used by, but not a part of, the organizational information system). Relationships with external service providers are established in a variety of ways, for example, through joint ventures, business partnerships, outsourcing arrangements (i.e., through contracts, interagency agreements, lines of business arrangements), licensing agreements, and/or supply chain exchanges. Ultimately, the responsibility for adequately mitigating risks to the organization’s operations and assets, and to individuals, arising from the use of external information system services remains with the authorizing official.

Read original · PDF 127 Source details Link to quote

NIST guidance

SP 800-53 Rev. 2 — Recommended Security Controls for Federal Information Systems

SA-9 supplemental guidance; PDF p. 130 including archive cover · 2007-12-19

An external information system service is a service that is implemented outside of the accreditation boundary of the organizational information system (i.e., a service that is used by, but not a part of, the organizational information system). Relationships with external service providers

are established in a variety of ways, for example, through joint ventures, business partnerships, outsourcing arrangements (i.e., through contracts, interagency agreements, lines of business arrangements), licensing agreements, and/or supply chain exchanges. Ultimately, the responsibility for adequately mitigating risks to the organization's operations and assets, and to individuals, arising from the use of external information system services remains with the authorizing official.

Read original · PDF 130 Source details Link to quote

SP 800-60 Revision 1 keeps information as the basis for categorization

2008 **NIST guidance**

The revised mapping guide still starts with information types and their consequences. It retains the explicit link to FISMA's second task and FIPS 199.

Where it came from

This updates the 2004 mapping guidance. The excerpt shows the retained method rather than a new rule for outsourcing.

What changed—or stayed

The reference to the system's use, connectivity, and aggregate information content remains. This edition does not replace the separate legal inquiry about who uses or operates a system and for what purpose.

NIST guidance

SP 800-60 Vol. 1 Rev. 1 — Guide for Mapping Types of Information and Information Systems to Security Categories

Volume I Revision 1, executive summary, p. vii · 2008-08-01

In response to the second of these tasks, this guideline has been developed to assist Federal government agencies to categorize information and information systems. The guideline's objective is to facilitate application of appropriate levels of information security according to a range of levels of impact or consequences that might result from the unauthorized disclosure, modification, or use of the information or information system. This guideline assumes that the user is familiar with Standards for Security Categorization of Federal Information and Information Systems (Federal Information Processing Standard [FIPS] 199). The guideline and its appendices: • Review the security categorization terms and definitions established by FIPS 199; • Recommend a security categorization process; • Describe a methodology for identifying types of Federal information and information systems; • Suggest provisional1 security impact levels for common information types; • Discuss information attributes that may result in variances from the provisional impact level assignment; and • Describe how to establish a system security categorization based on the system's use, connectivity, and aggregate information content.

Read original · PDF 7 Source details Link to quote

SP 800-53 Revision 3 makes oversight roles explicit

2009 / updated 2010 **NIST guidance**

SA-9 now lists three duties: require compliant controls, document government oversight and user roles, and monitor the provider's compliance.

Where it came from

This continues the external-services control in Revisions 1 and 2. The catalog supports the FIPS 200 control-selection process.

What changed—or stayed

The control text makes the oversight allocation explicit. The saved Revision 3 PDF incorporates an August 2010 update, so this quotation is evidence for that edition, not proof of the precise day each word first appeared.

Edition note. Revision 3 first published August 2009; saved file identifies August 2010 updates and includes an archive cover.

NIST guidance

SP 800-53 Rev. 3 — Recommended Security Controls for Federal Information Systems and Organizations

SA-9 control; PDF p. 176 including archive cover · 2009; updated August 2010

The organization: a. Requires that providers of external information system services comply with organizational information security requirements and employ appropriate security controls in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance; b. Defines and documents government oversight and user roles and responsibilities with regard to external information system services; and c. Monitors security control compliance by external service providers.

Read original · PDF 176 Source details Link to quote

2010–2013

Purchased services and continuing oversight

SP 800-37 Revision 1 extends the risk framework across the life cycle

2010 **NIST guidance**

The revised guide organized categorization, control selection, implementation, assessment, authorization, and monitoring into the Risk Management Framework. Its discussion of complex systems expressly addresses external subsystems.

Where it came from

The passage cites SP 800-53 Appendix I, “Security Controls in External Environments,” and attributes its requirement to FISMA and OMB policy.

What changed—or stayed

NIST applies federal security requirements to external subsystems handling federal information and their associated services. Its surrounding discussion acknowledges limited direct control and the need for evidence and trust. This wording predates the 2016 A-130 revision.

NIST guidance

SP 800-37 Rev. 1 — Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach

§2.4, printed p. 15; Appendix I referenced here is in SP 800-53 · 2010-02-22

As noted in Appendix I (Security Controls in External Environments), FISMA and OMB policy require external providers handling federal information or operating information systems on behalf of the federal government to meet the same security requirements as federal agencies. These security requirements also apply to external subsystems storing, processing, or transmitting federal information and any services provided by or associated with the subsystem.

Read original · PDF 23 Source details Link to quote

OMB expressly includes subscribed and outsourced services

2010 **OMB policy**

The FY2010 instructions connect FISMA’s agency-program requirement to fully or partly provided services, expressly including software as a service. They separately retain agency accountability for information on incidental equipment.

Where it came from

M-10-15 questions 36–38 interpret the existing FISMA framework and refer back to A-130 and NIST. This extends the earlier reporting guidance into more explicit service language.

What changed—or stayed

The historical instruction to use “identical, not equivalent” procedures is particularly strong. It belongs to these 2010 instructions. Later FedRAMP policy provides reuse and authorization paths; do not treat this sentence alone as the complete current process.

OMB policy

M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management

FY2010 reporting instructions, question 36, printed p. 13 · 2010-04-21

Section 3544(b) requires each agency to provide information security for the information and “information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source.” This includes services which are either fully or partially provided, including agency hosted, outsourced, and software-as-a-service (SaaS) solutions.

Read original · PDF 17 Source details Link to quote

OMB policy

M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management

Question 36, printed p. 14 · 2010-04-21

Finally, because FISMA applies to Federal information and information systems, in certain limited circumstances its requirements also apply to a specific class of information technology to which Clinger-Cohen did not, i.e., “equipment that is acquired by a Federal contractor incidental to a Federal contract.” Therefore, when Federal information is used within incidentally acquired equipment, the agency continues to be responsible and accountable for ensuring FISMA requirements are met.

Read original · PDF 18 Source details Link to quote

OMB policy

M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management

Question 38, service providers, printed p. 15; historical 2010 instructions · 2010-04-21

Agencies are fully responsible and accountable for ensuring all FISMA and related policy requirements are implemented and reviewed and such must be included in the terms of the contract. Agencies must ensure identical, not "equivalent," security procedures. For example, annual reviews, risk assessments, security plans, control testing, contingency planning, and security authorization (C&A) must, at a minimum, explicitly meet guidance from NIST.

Read original · PDF 19 Source details Link to quote

Records obligations also follow information into a service

2010 **Guidance**

NARA explained that records-management responsibilities need to be addressed in cloud contracts. Information security does not replace recordkeeping, retention, access, or lawful disposal.

Where it came from

NARA Bulletin 2010-05 applies records-management responsibilities to cloud environments. This is a related information-management stream, not the origin of FISMA or the RMF.

What changed—or stayed

An agency can retain records responsibilities even when another organization supplies the service. The security authorization alone does not settle those duties.

Guidance

NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments

NARA Bulletin 2010-05, question 6 · 2010-09-08

In the SaaS service model, the agency may maintain records in contractor-provided clouds, and any negotiated contract language will need to address specific records management responsibilities.

Read original Source details Link to quote

FedRAMP provides a common assessment and authorization process

2011 **OMB policy**

OMB's December memorandum established FedRAMP policy for agencies procuring cloud services. Its scope expressly included commercial and non-commercial services, public and other deployment models, and the principal service models.

Where it came from

The memorandum built a reusable approach around existing FISMA and NIST requirements. NIST SP 800-144 separately explained why security and privacy accountability remains with the agency.

What changed—or stayed

A shared service and an external operator did not, by themselves, remove the service from the policy. The memorandum contained a specific on-premises, agency-only private-cloud exception; that exception still required FISMA and NIST compliance.

OMB policy

Security Authorization of Information Systems in Cloud Computing Environments

§3(a), printed p. 2; read with §3(b)–(c) and private-cloud exception in footnote 4 · 2011-12-08

Executive departments and agencies procuring commercial and non-commercial cloud services that are provided by information systems that support the operations and assets of the departments and agencies, including systems provided or managed by other departments or agencies, contractors, or other sources;

Read original · PDF 2 Source details Link to quote

NIST guidance

SP 800-144: Security and Privacy in Public Cloud Computing

§6, Conclusion, printed p. 52 · 2011-12-01

Accountability for security and privacy in public cloud deployments cannot be delegated to a cloud provider and remains an obligation for the organization to fulfill. Federal agencies must ensure that any selected public cloud computing solution is configured, deployed, and managed to meet the security, privacy, and other requirements of the organization. Organizational data must be protected in a manner consistent with policies, whether in the organization's computing center or the cloud. The organization must ensure that security and privacy controls are implemented correctly and operate as intended, throughout the system lifecycle.

Read original · PDF 62 Source details Link to quote

SP 800-53 Revision 4 ties external services to federal requirements

2013 / updated 2015 **NIST guidance**

SA-9 again distinguishes the service from the organizational system's authorization boundary. It expressly covers providers processing, storing, or transmitting federal information, or operating systems for the government.

Where it came from

The guidance states its connection to FISMA and OMB policy. Revision 4 also brought privacy controls into the catalog.

What changed—or stayed

The requirement is not limited to systems inside an agency-drawn boundary. The organization must establish what the external service protects and how compliance will be monitored. This is guidance about applying duties, not a new act of Congress.

Edition note. Revision 4 published April 2013; this saved PDF includes updates through January 22, 2015.

NIST guidance

SP 800-53 Rev. 4: Security and Privacy Controls

Revision 4, SA-9 supplemental guidance, p. F-162; saved edition includes January 22, 2015 update · 2013; updated January 2015

External information system services are services that are implemented outside of the authorization boundaries of organizational information systems. This includes services that are used by, but not a part of, organizational information systems. FISMA and OMB policy require that organizations using external service providers that are processing, storing, or transmitting federal information or operating information systems on behalf of the federal government ensure that such providers meet the same security requirements that federal agencies are required to meet. Organizations establish relationships with external service providers in a variety of ways including, for example, through joint ventures, business partnerships, contracts, interagency agreements, lines of business arrangements, licensing agreements, and supply chain exchanges. The responsibility for managing risks from the use of external information system services remains with authorizing officials.

Read original · PDF 320 Source details Link to quote

OMB requires a strategy for continuing authorization and monitoring

2013 **OMB policy**

M-14-03 directed agencies to implement continuous monitoring of controls in phases through FY2017. The strategy had to address ongoing authorizations and environments of operation.

Where it came from

The memorandum explicitly cites the RMF and NIST guidance, including SP 800-37, 800-39, 800-53, 800-53A, and 800-137.

What changed—or stayed

The management task continues after initial approval. Agencies need a way to learn about changing risks and control performance, including where they rely on shared controls.

OMB memorandum

M-14-03, Enhancing the Security of Federal Information and Information Systems

p. 2, action 1; ISCM means information security continuous monitoring · 2013-11-18

To fully implement ISCM across the Government, agencies shall: 1) Develop and maintain, consistent with existing statutes, OMB policy, NIST guidelines10 and the CONOPS, an ISCM strategy, and establish an ISCM program that: a. Provides a clear understanding of organizational risk and helps officials set priorities and manage such risk consistently throughout the agency; and b. Addresses how the agency will conduct ongoing authorizations of information systems and the environments in which those systems operate, including the agency's use of common controls.

Read original · PDF 2 Source details Link to quote

2014–2016

The statutory continuity and the CUI split

The RMF update retains its external-services wording

June 2014 **NIST guidance**

The June update to SP 800-37 Revision 1 retained the passage about external providers, subsystems, and associated services.

Where it came from

The original February 2010 text and the June 2014 updated edition are preserved separately. Their quoted passages match.

What changed—or stayed

This update preceded the December 2014 FISMA law. It cannot be described as implementing that later enactment.

NIST guidance

SP 800-37 Rev. 1 — Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach

§2.4, printed p. 15; June 5, 2014 update, archive wrapper included · 2014-06-05

As noted in Appendix I (Security Controls in External Environments), FISMA and OMB policy require external providers handling federal information or operating information systems on behalf of the federal government to meet the same security requirements as federal agencies. These security requirements also apply to external subsystems storing, processing, or transmitting federal information and any services provided by or associated with the subsystem.

Read original · PDF 33 Source details Link to quote

FISMA modernization retains the two objects of protection

December 2014 **Law**

The Federal Information Security Modernization Act of 2014 retained the information/system distinction in 44 USC 3554. Compare the first quotation with 2002: the shared duty and both objects have the same wording.

Where it came from

Public Law 113–283 replaced the prior subchapter and revised federal oversight and operational responsibilities, including OMB and DHS roles. The quoted agency provisions are §§3554(a) and (b).

What changed—or stayed

Agencies must assess harm, determine appropriate security, implement risk-reducing policies, and test controls. The agency-wide program still includes externally provided or managed information and systems. Risk management and compliance are concurrent duties.

Law

Federal Information Security Modernization Act

§2, 44 USC 3554(a)(1)(A); 128 Stat. 3078 · 2014-12-18

“(A) providing information security protections commensurate with the risk and magnitude of the harm resulting from unauthorized access, use, disclosure, disruption, modification, or destruction of—

“(i) information collected or maintained by or on behalf of the agency; and

“(ii) information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency;

Read original · PDF 6 Source details Link to quote

Law

Federal Information Security Modernization Act

44 USC 3554(a)(2); 128 Stat. 3078 · 2014-12-18

“(2) ensure that senior agency officials provide information security for the information and information systems that support the operations and assets under their control, including through —

“(A) assessing the risk and magnitude of the harm that could result from the unauthorized access, use, disclosure, disruption, modification, or destruction of such information or information systems;

“(B) determining the levels of information security appropriate to protect such information and information systems in accordance with standards promulgated under section 11331 of title 40, for information security classifications and related requirements;

“(C) implementing policies and procedures to cost-effectively reduce risks to an acceptable level; and

“(D) periodically testing and evaluating information security controls and techniques to ensure that they are effectively implemented;

Read original · PDF 6 Source details Link to quote

Law

Federal Information Security Modernization Act

44 USC 3554(b); 128 Stat. 3079 · 2014-12-18

Each agency shall develop, document, and implement an agency-wide information security program to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source, that includes—

Read original · PDF 7 Source details Link to quote

SP 800-171 creates a tailored path for CUI in nonfederal systems

2015 **NIST guidance**

SP 800-171 addressed the confidentiality of controlled unclassified information held in qualifying nonfederal systems. CUI is information requiring safeguards under a law, regulation, or government-wide policy; it is not a synonym for all federal information.

Where it came from

The publication was developed for the CUI program established by Executive Order 13556. Its requirements were derived from federal standards and SP 800-53, tailored for this narrower setting. The 2015 text referred to a proposed CUI rule.

What changed—or stayed

The distinction was already express: the main scope excluded systems used or operated for agencies, while footnote 8 also excluded organizations collecting or maintaining information for them. Read the footnote with the main text. SP 800-171 was never a general substitute for federal-system requirements.

Edition note. June 2015 publication; saved PDF incorporates January 2016 updates. Do not read its references to a proposed rule as final 2016 rule text.

NIST guidance

SP 800-171: Protecting CUI in Nonfederal Systems

§1.1, printed p. 2; June 2015 text, saved PDF includes January 2016 update · 2015; updated January 2016

The purpose of this publication is to provide federal agencies with recommended requirements for protecting the confidentiality of CUI: (i) when the CUI is resident in nonfederal information systems and organizations; (ii) when the information systems where the CUI resides are not used or operated by contractors of federal agencies or other organizations on behalf of those agencies;8 and (iii) where there are no specific safeguarding requirements for protecting the confidentiality of CUI prescribed by the authorizing law, regulation, or governmentwide policy for the CUI category or subcategory listed in the CUI Registry. The requirements apply only to components9 of nonfederal information systems that process, store, or transmit CUI, or that provide security protection for such components. The CUI requirements are intended for use by federal agencies in appropriate contractual vehicles or other agreements established between those agencies and nonfederal organizations.

Read original · PDF 13 Source details Link to quote

NIST guidance

SP 800-171: Protecting CUI in Nonfederal Systems

§1.1 footnote 8, printed p. 2 · 2015; updated January 2016

Nonfederal organizations that collect or maintain information on behalf of a federal agency or that operate or use information systems on behalf of a federal agency, must comply with the requirements in the Federal Information Security Modernization Act (FISMA), including the

minimum security requirements in FIPS Publication 200 and the security controls in NIST Special Publication 800-53.

Read original · PDF 13 Source details Link to quote

NIST guidance

SP 800-171: Protecting CUI in Nonfederal Systems

§1.1, printed p. 3 · 2015; updated January 2016

The specific requirements for safeguarding CUI in nonfederal information systems and organizations are derived from the above authoritative federal standards and guidelines to maintain a consistent level of protection. However, recognizing that the scope of the safeguarding requirements in the proposed federal CUI regulation is limited to the security objective of confidentiality (i.e., not directly addressing integrity and availability) and that some of the FISMA-related requirements expressed in the NIST standards and guidelines are uniquely federal, the requirements in this publication have been tailored for nonfederal entities. The tailoring criteria, described in Chapter Two, are not intended to reduce or minimize the federal requirements for the safeguarding of CUI as expressed in the proposed federal CUI regulation. Rather, the intent is to express the requirements in a manner that allows for and facilitates the equivalent safeguarding measures within nonfederal information systems and organizations and does not diminish the level of protection of CUI required for moderate confidentiality.

Read original · PDF 14 Source details Link to quote

A-130 separates definitions and spells out agency oversight

July 2016 **OMB policy**

The revised circular defines federal information with lifecycle verbs and federal information systems with use/operation language. Appendix I then addresses agreements and oversight of non-federal entities.

Where it came from

Section 9 cites the PRA, E-Government Act, FISMA 2014, Clinger–Cohen, and other authorities. Appendix I §5(r) expressly explains FISMA applicability; §4(j) gives the operative agency directions.

What changed—or stayed

Section 4(j)(1) covers agreements involving the lifecycle of federal information. Section 4(j)(2) has an "or": systems used or operated for government, OR systems collecting or maintaining federal information for it. Its oversight duties include controls, inventory, interfaces, access, and incident response. An information-handling arrangement can therefore trigger more than a general instruction to understand risk.

OMB policy

A-130: Managing Information as a Strategic Resource

§10(a)(22)–(23), printed p. 29 · 2016-07-28

22) ‘Federal information’ means information created, collected, processed, maintained, disseminated, disclosed, or disposed of by or for the Federal Government, in any medium or form.
23) ‘Federal information system’ means an information system used or operated by an agency or by a contractor of an agency or by another organization on behalf of an agency.

Read original · PDF 29 Source details Link to quote

OMB policy

A-130: Managing Information as a Strategic Resource

Appendix I §4(j)(1), printed p. 14 · 2016-07-28

1) Ensure that terms and conditions in contracts and other agreements involving the creation, collection, use, processing, storage, maintenance, dissemination, disclosure, and disposal of Federal information, incorporate security and privacy requirements and are sufficient to enable agencies to meet Federal and agency-specific requirements pertaining to the protection of Federal information;

Read original · PDF 51 Source details Link to quote

OMB policy

A-130: Managing Information as a Strategic Resource

Appendix I §4(j)(2)(a)–(d), printed p. 14 · 2016-07-28

2) Provide oversight of information systems used or operated by contractors or other entities on behalf of the Federal Government or that collect or maintain Federal information on behalf of the Federal Government, to include:

a) Documenting and implementing policies and procedures for information security and privacy oversight, to include ensuring appropriate vetting and access control processes for contractors and others with access to information systems containing Federal information;

b) Ensuring that security and privacy controls of such information systems and services are effectively implemented and comply with NIST standards and guidelines and agency requirements;

c) Ensuring that these information systems are included in the agency’s inventory of information systems;

d) Ensuring that the interface characteristics, security requirements, and the nature of the information communicated is documented for each interface between these systems and agency-owned or operated information systems;

Read original · PDF 51 Source details Link to quote

OMB policy

A-130: Managing Information as a Strategic Resource

Appendix I §4(j)(2)(e)–(f), printed p. 14 · 2016-07-28

e) Ensuring that procedures are in place for incident response for these information systems including timelines for notification of affected individuals and reporting to OMB, DHS, and other entities as required in OMB guidance;

f) Requiring agreements (e.g., memoranda of understanding, interconnection security agreements, contracts) for interfaces between these information systems and agency-owned or operated information systems;

Read original · PDF 51 Source details Link to quote

OMB policy

A-130: Managing Information as a Strategic Resource

Appendix I §5(r), printed p. 25 · 2016-07-28

FISMA describes Federal agency security responsibilities as including “information collected or maintained by or on behalf of an agency” and “information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency.” FISMA requires each agency to provide information security for the information and “information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source.” This includes services that are either fully or partially provided, including agency-hosted, outsourced, and cloud-based solutions.

Read original · PDF 62 Source details Link to quote

OMB policy

A-130: Managing Information as a Strategic Resource

Appendix I §5(r), printed p. 26 · 2016-07-28

Therefore, when Federal information is used within incidentally acquired equipment, the agency continues to be responsible and accountable for ensuring that FISMA requirements are met for such information.

Read original · PDF 63 Source details Link to quote

OMB policy

A-130: Managing Information as a Strategic Resource

Appendix I §4(d)(1), printed p. 7 · 2016-07-28

1) Designate senior Federal officials to formally authorize an information system to operate and authorize agency-designated common controls for use;

Read original · PDF 44 Source details Link to quote

The CUI rule states an explicit federal/nonfederal split

September–November 2016 **Regulation**

NARA's final rule distinguishes systems operated for an agency from other nonfederal systems holding CUI. The first category includes outsourced processing services, even when the system serves both government and private users.

Where it came from

The rule implements Executive Order 13556 and incorporates FIPS 199, FIPS 200, SP 800-53, and SP 800-171. It was published September 14 and effective November 14, 2016.

What changed—or stayed

For qualifying nonfederal systems, the rule prohibits treating them as agency systems and directs agencies to use SP 800-171 for CUI confidentiality, with stated exceptions. Its incidental-handling language expressly excludes processing services from that example. This is a scoped CUI rule, not a blanket exemption for commercial systems.

Regulation

NARA CUI final rule and comment responses

32 CFR 2002.14(h)(1), 81 FR 63341; final rule effective November 14, 2016 · 2016-09-14

(1) A Federal information system is an information system used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency. An information system operated on behalf of an agency provides information processing services to the agency that the Government might otherwise perform itself but has decided to outsource. This includes systems operated exclusively for Government use and systems operated for multiple users (multiple Federal agencies or Government and private sector users). Information systems that a non-executive branch entity operates on behalf of an agency are subject to the requirements of this part as though they are the agency's systems, and agencies may require these systems to meet additional requirements the agency sets for its own internal systems.

Read original · PDF 18 Source details Link to quote

Regulation

NARA CUI final rule and comment responses

32 CFR 2002.14(h)(2), 81 FR 63341; quoted with both exceptions · 2016-09-14

(2) A non-Federal information system is any information system that does not meet the criteria for a Federal information system. Agencies may not treat non-Federal information systems as though they are agency systems, so agencies cannot require that non-executive branch entities protect these systems in the same manner that the agencies might protect their own information systems. When a non-executive branch entity receives Federal information only incidental to providing a service or product to the Government other than processing services, its information systems are not considered Federal information systems. NIST SP 800–171 (incorporated by reference, see § 2002.2) defines the requirements necessary to protect CUI Basic on non-Federal information systems in accordance with the requirements of this part. Agencies must use NIST SP 800–171

when establishing security requirements to protect CUI's confidentiality on non-Federal information systems (unless the authorizing law, regulation, or Government-wide policy listed in the CUI Registry for the CUI category or subcategory of the information involved prescribes specific safeguarding requirements for protecting the information's confidentiality, or unless an agreement establishes requirements to protect CUI Basic at higher than moderate confidentiality).

Read original · PDF 18 Source details Link to quote

Regulation

NARA CUI final rule and comment responses

81 FR 63326, response on §2002.1 scope; agency explanation · 2016-09-14

We determined from the number and scope of the comments that we needed to thoroughly revise this section to make it clearer. This section merely spells out that the regulation's scope of impact will include non-executive branch entities by means of the requirement on agencies to include contract or agreement provisions regarding CUI, when relevant. Accordingly, we have revised the language to not only state that the rule applies to only agencies directly, but to also show that by the organization of the section.

Read original · PDF 3 Source details Link to quote

SP 800-171 Revision 1 makes both exclusions explicit in the main scope

December 2016 / updated 2018 **NIST guidance**

Revision 1's scope says both "not collecting or maintaining information" for an agency and not using or operating a system for one. The earlier edition put the information condition in a footnote; the revised main paragraph makes it visible.

Where it came from

The revision responds to the now-final CUI framework and continues the FIPS/SP 800-53 tailoring approach.

What changed—or stayed

Compared with the collected 2015 edition, Revision 1 also includes requirement 3.12.4 on system security plans. A nonfederal system can have a documented plan and connections without becoming an agency system. The applicable authority and agreement determine the obligation.

Edition note. The quoted Revision 1 file includes updates through June 7, 2018. Intermediate 2017/2018 update wording is not separately reconstructed here.

NIST guidance

SP 800-171 Rev. 1 — Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

§1.1, printed p. 2; Revision 1 December 2016, saved edition updated June 7, 2018 · 2016; updated June 2018

The purpose of this publication is to provide federal agencies with recommended security requirements for protecting the confidentiality of CUI when the CUI is resident in a nonfederal system and organization; when the nonfederal organization is not collecting or maintaining information on behalf of a federal agency or using or operating a system on behalf of an agency; 6 and where there are no specific safeguarding requirements for protecting the confidentiality of CUI prescribed by the authorizing law, regulation, or governmentwide policy for the CUI category or subcategory listed in the CUI Registry.7 The security requirements apply only to components of nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components.8 The security requirements are intended for use by federal agencies in appropriate contractual vehicles or other agreements established between those agencies and nonfederal organizations.

Read original · PDF 20 Source details Link to quote

NIST guidance

SP 800-171 Rev. 1 — Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

§3.12.4, printed p. 14; footnote 26 does not prescribe a plan format · 2016; updated June 2018

3.12.4 Develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.

Read original · PDF 32 Source details Link to quote

2018–2021

Information owners, external systems, and exchanges

SP 800-37 Revision 2 distinguishes information stewardship from system ownership

2018 **NIST guidance**

The revised RMF integrates security and privacy and adds organizational preparation. Its role descriptions make a useful distinction: the information owner retains protection responsibilities when sharing information, while the authorizing official can authorize use of an external service.

Where it came from

The publication cites FISMA 2014 and the 2016 A-130. Appendix G continues the external-provider discussion from the earlier RMF and control catalog.

What changed—or stayed

NIST pairs a strong statement about applicable requirements with practical risk responses where direct control is limited. “Authorization to use” and an acceptable exchange risk do not make statutory or policy requirements disappear. They describe how the agency decides whether to rely on the service.

NIST guidance

SP 800-37 Rev. 2: Security and Privacy RMF

Appendix D, Information Owner or Steward, printed p. 119 · 2018-12-20

In information-sharing environments, the information owner/steward is responsible for establishing the rules for appropriate use and protection of the information and retains that responsibility even when the information is shared with or provided to other organizations. The owner/steward of the information processed, stored, or transmitted by a system may or may not be the same individual as the system owner.

Read original · PDF 138 Source details Link to quote

NIST guidance

SP 800-37 Rev. 2: Security and Privacy RMF

Appendix D, Authorizing Official, printed p. 114 · 2018-12-20

The authorizing official is a senior official or executive with the authority to formally assume responsibility and accountability for operating a system; providing common controls inherited by organizational systems; or using a system, service, or application from an external provider.

Read original · PDF 133 Source details Link to quote

NIST guidance

SP 800-37 Rev. 2: Security and Privacy RMF

Appendix G, printed p. 159 · 2018-12-20

FISMA and OMB policy require external providers that process, store, or transmit federal information or operate information systems on behalf of the federal government to meet the same security and privacy requirements as federal agencies. Federal security and privacy requirements also apply to external systems storing, processing, or transmitting federal information and any services provided by or associated with the external system.

Read original · PDF 178 Source details Link to quote

NIST guidance

SP 800-37 Rev. 2: Security and Privacy RMF

Appendix G, printed p. 160; an alternative risk response, not a waiver of law · 2018-12-20

Alternatively, organizations may allow externally provided systems or services to be used only in those instances where the exchange of information risk determined by the organization is acceptable.

Read original · PDF 179 Source details Link to quote

SP 800-171 Revision 2 explains agreements and bounded protection

2020 / updated 2021 **NIST guidance**

The front matter states when these recommended requirements apply to a nonfederal organization: when an agency mandates them in a contract, grant, or other agreement. The scope remains CUI confidentiality in qualifying nonfederal systems.

Where it came from

Revision 2 continues the CUI rule and SP 800-53-based approach. Its §1.1 retains the information-handling and system-operation exclusions.

What changed—or stayed

The publication expressly permits a separate CUI security domain to limit the components that must satisfy these requirements. That is a concrete scoping provision. It is not a rule limiting all FISMA duties to an agency-controlled tenant.

Edition note. February 2020 edition, including January 28, 2021 updates; later withdrawal cover is retained.

NIST guidance

SP 800-171 Rev. 2 — Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

Revision 2, front matter p. vii; February 2020, includes January 28, 2021 updates · 2020; updated January 2021

The recommended security requirements contained in this publication are only applicable to a nonfederal system or organization when mandated by a federal agency in a contract, grant, or other agreement. The security requirements apply to the components of nonfederal systems that

process, store, or transmit CUI, or that provide security protection for such components.

Read original · PDF 10 Source details Link to quote

NIST guidance

SP 800-171 Rev. 2 — Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

§1.1, printed p. 2 · 2020; updated January 2021

If nonfederal organizations designate specific system components for the processing, storage, or transmission of CUI, those organizations may limit the scope of the security requirements by isolating the designated system components in a separate CUI security domain. Isolation can be achieved by applying architectural and design concepts (e.g., implementing subnetworks with firewalls or other boundary protection devices and using information flow control mechanisms). Security domains may employ physical separation, logical separation, or a combination of both. This approach can provide adequate security for the CUI and avoid increasing the organization's security posture to a level beyond that which it requires for protecting its missions, operations, and assets.

Read original · PDF 15 Source details Link to quote

SP 800-53 Revision 5: controls for organizations and services

2020 NIST guidance

Revision 5's SA-9 requires external providers to meet organizational security and privacy requirements, documents oversight roles, and calls for ongoing monitoring. Its discussion expressly contemplates that the organization has no direct control over implementation or assessment.

Where it came from

Revision 5 is the successor control catalog. Baselines moved to the companion SP 800-53B; FIPS 200 continues to connect federal minimum requirements to control selection.

What changed—or stayed

The catalog supports federal and nonfederal uses. A control's presence in it is not, by itself, proof that every private company must implement it. Selection, applicable law and policy, and agreements supply that link.

Edition note. September 2020 publication, including December 10, 2020 updates. Later release changes are addressed below.

NIST guidance

SP 800-53 Rev. 5: Security and Privacy Controls

Revision 5, SA-9 control and discussion; September 2020, includes December 10, 2020 updates · 2020; updated December 2020

Control: a. Require that providers of external system services comply with organizational security and privacy requirements and employ the following controls: [Assignment: organization-defined controls]; b. Define and document organizational oversight and user roles and responsibilities with regard to external system services; and c. Employ the following processes, methods, and techniques to monitor control compliance by external service providers on an ongoing basis: [Assignment: organization-defined processes, methods, and techniques]. Discussion: External system services are provided by an external provider, and the organization has no direct control over the implementation of the required controls or the assessment of control effectiveness. Organizations establish relationships with external service providers in a variety of ways, including through business partnerships, contracts, interagency agreements, lines of business arrangements, licensing agreements, joint ventures, and supply chain exchanges. The responsibility for managing risks from the use of external system services remains with authorizing officials.

Read original · PDF 298 Source details Link to quote

SP 800-47 Revision 1 centers the information exchange

2021 **NIST guidance**

The revised guide addresses information before, during, and after an exchange. It is technology-neutral and applies across different organizations or different authorization boundaries within one organization.

Where it came from

It expands the earlier interconnection-security focus into management of information exchanges. Its guidance complements the RMF and A-130's interface and agreement duties.

What changed—or stayed

Protecting exchanged information and authorizing the systems are related but distinct work. Participating organizations need to identify risks, required protections, responsible officials, and suitable agreements. Connectivity alone does not decide whether one organization operates for another.

NIST guidance

NIST SP 800-47 Revision 1

§1, printed p. 1 · 2021-07-20

However, it is recognized that the information being exchanged also requires the same or similar level of protection as it moves from one organization to another (protection commensurate with risk). This publication focuses on managing the protection of the information being exchanged or accessed before, during, and after the exchange and provides guidance on identifying information exchanges, considerations for protecting exchanged information, and the agreement(s) needed to help manage the risk associated with exchanging information.

Read original · PDF 10 Source details Link to quote

NIST guidance

NIST SP 800-47 Revision 1

§1.1, printed p. 1 · 2021-07-20

This publication provides guidance for managing (i.e., planning, establishing, maintaining, and discontinuing) the security of information exchanges between systems that are owned and operated by different organizations or are within the same organization but with different authorization boundaries, including organizations within a single federal agency.

Read original · PDF 10 Source details Link to quote

2022–2026

Cloud legislation and current guidance

Congress codifies FedRAMP and directs OMB to define its scope

2022 **Law**

The FedRAMP Authorization Act establishes a reusable assessment and authorization program for cloud products and services processing unclassified information used by agencies. It imports A-130's definitions of federal information and authorization to operate.

Where it came from

Public Law 117–263 §5921 adds 44 USC 3607–3616. Section 3614 specifically directs OMB to issue scope and authorization guidance.

What changed—or stayed

The statute's reference to services operated as federal information systems must be read with OMB's ensuing scope policy. Reusing a FedRAMP package also does not remove an agency's FISMA responsibility: §3613(e)(2) preserves it expressly.

Law

FedRAMP Authorization Act in P.L. 117-263

§5921, 44 USC 3607(b)(3); 136 Stat. 3449 · 2022-12-23

The terms 'authorization to operate' and 'Federal information' have the meaning given those term in Circular A–130 of the Office of Management and Budget entitled 'Managing Information as a Strategic Resource', or any successor document.

Read original · PDF 1055 Source details Link to quote

Law

FedRAMP Authorization Act in P.L. 117-263

44 USC 3608; 136 Stat. 3450 · 2022-12-23

There is established within the General Services Administration the Federal Risk and Authorization Management Program. The Administrator, subject to section 3614, shall establish a Government-wide program that provides a standardized, reusable approach to security assessment and authorization for cloud computing products and services that process unclassified information used by agencies.

Read original · PDF 1056 Source details Link to quote

Law

FedRAMP Authorization Act in P.L. 117-263

44 USC 3614(1); 136 Stat. 3454 · 2022-12-23

“(1) in consultation with the Administrator and the Secretary, issue guidance that—

“(A) specifies the categories or characteristics of cloud computing products and services that are within the scope of FedRAMP;

“(B) includes requirements for agencies to obtain a FedRAMP authorization when operating a cloud computing product or service described in subparagraph (A) as a Federal information system; and

“(C) encompasses, to the greatest extent practicable, all necessary and appropriate cloud computing products and services;

Read original · PDF 1060 Source details Link to quote

Law

FedRAMP Authorization Act in P.L. 117-263

44 USC 3613(e)(2); 136 Stat. 3454 · 2022-12-23

“(2) INFORMATION SECURITY REQUIREMENTS.—The presumption under paragraph (1) does not modify or alter—

“(A) the responsibility of any agency to ensure compliance with subchapter II of chapter 35 for any cloud computing product or service used by the agency; or

“(B) the authority of the head of any agency to make a determination that there is a demonstrable need for additional security requirements beyond the security requirements included in a FedRAMP authorization for a particular control implementation.

Read original · PDF 1060 Source details Link to quote

DHS declines to adopt NARA’s definition for all of its FISMA rule

2023 **Comment response**

Public comments on DHS’s safeguarding rule questioned how it distinguished federal and nonfederal systems and how it used “on behalf of an agency.” DHS intentionally declined to import the CUI rule’s definition.

Where it came from

This is DHS’s response in the final-rule preamble, 88 FR 40571. The agency argued that a general FISMA definition should come from OMB after interagency coordination.

What changed—or stayed

The response is evidence of an unresolved difference in agency interpretation. It does not repeal NARA’s CUI rule, supply a court holding, or establish a universal commercial-service exemption. Its immediate context is DHS acquisition rules.

Regulation

DHS safeguarding final rule and comment responses

88 FR 40571, response under definition of Federal information system; DHS explanation · 2023-06-21

DHS intentionally excluded the "on behalf of an agency" definition provided in the NARA CUI rule from this rulemaking. The phrase "on behalf of an agency" is already rooted in statute and is used extensively in FISMA. FISMA designates the Director of the OMB as being responsible for "developing and overseeing the implementation of policies, principles, standards, and guidelines on information security…." 44 U.S.C. 3553(a)(1). As such, any definition of the phrase "on behalf of an agency" must be provided in FISMA policy and guidance issued by OMB after going through the appropriate interagency coordination process to assess the wide-ranging implications of defining this term. In the case of the NARA CUI rule, that has not happened.

Read original · PDF 12 Source details Link to quote

SP 800-171 Revision 3 retains the narrower scope

May 2024 **NIST guidance**

Revision 3 continues to exclude organizations collecting or maintaining information for an agency, or using or operating its systems. Its requirements apply to components handling CUI or protecting those components and are intended for agreements with agencies.

Where it came from

The revision updates the requirements using the SP 800-53 Revision 5 catalog. NIST's February 2024 public-comment analysis discusses alignment with source controls and tailoring for CUI confidentiality.

What changed—or stayed

This is the current final SP 800-171 edition checked for this report. The component limit is express. The publication's information-handling exclusion is equally express; neither should be omitted when deciding whether this is the right requirements set.

NIST guidance

SP 800-171 Rev. 3: Protecting CUI

Revision 3 §1.1, printed p. 2; read with footnote 8 on FISMA · 2024-05-14

The requirements do not apply to nonfederal organizations that are collecting or maintaining information on behalf of a federal agency or using or operating a system on behalf of an agency.8 8 Nonfederal organizations that collect or maintain information on behalf of a federal agency or that use or operate a system on behalf of an agency must comply with the requirements in FISMA [9]. The security requirements in this publication are only applicable to components of nonfederal systems that process, store, or transmit CUI or that provide protection for such components.9 9 System components include workstations, servers, notebook computers, smartphones, tablets, input and output devices, network components, operating systems, virtual machines, database management systems, and applications. The requirements are intended for use by federal agencies in contractual vehicles or other agreements that are established between those agencies and nonfederal organizations.

Read original · PDF 12 Source details Link to quote

OMB defines FedRAMP scope using information-handling verbs

July 2024 **OMB policy**

M-24-15 describes in-scope cloud products and services as those creating, collecting, processing, storing, or maintaining federal information for an agency, subject to the memorandum's exclusions.

Where it came from

The memorandum implements the FedRAMP Authorization Act and replaces the 2011 cloud authorization memorandum. The statute directed OMB to specify the categories and characteristics in scope.

What changed—or stayed

FedRAMP scope is a program decision with express exclusions, not a universal definition for every law. Agencies use the package for their own authorization to operate or use; other information-management, privacy, records, and security duties remain.

OMB policy

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

§III, printed p. 5; exclusions immediately follow · 2024-07-25

The scope of FedRAMP is cloud computing products and services (such as IaaS, Platform-as-a-Service (PaaS), and SaaS) that create, collect, process, store, or maintain Federal information on behalf of a Federal agency, and that are not otherwise specified as out of scope below.

Read original · PDF 5 Source details Link to quote

OMB policy

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

§III, exclusions 1–6, printed p. 5; footnote 6 limits scope to unclassified, non-national-security systems · 2024-07-25

The following categories of cloud computing products and services are specified as outside the scope of FedRAMP, subject to exceptions made by the FedRAMP Director with the approval of OMB:

1) Information systems that are only used for a single agency's operations, hosted on cloud infrastructure or platform, and are not offered as a shared service or do not operate with a shared responsibility model;

2) Social media and communications platforms used in accordance with agency social media policies;

3) Search engines;

4) Widely available services that provide commercially available information to agencies, but do not collect Federal information;

5) Ancillary services whose compromise would pose a negligible risk to Federal information or information systems, such as systems that make external measurements or only ingest information from other publicly available services; and

6) Any other categories of products or services identified for exclusion by the FedRAMP Board, with the concurrence of the Federal CIO.

Read original · PDF 5 Source details Link to quote

OMB policy

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

§IV footnote 7, printed p. 6 · 2024-07-25

Agencies leverage the FedRAMP authorization package to issue their own "authorization to operate" (ATO) or "authorization to use" (ATU). FedRAMP does not replace other legal, Executive Order, regulatory, or OMB-issued compliance requirements for areas such as information management, records management, privacy, and cybersecurity.

Read original · PDF 6 Source details Link to quote

SP 800-53 Release 5.2.0 updates controls without replacing the basic framework

2025 NIST guidance

The August release targets software updates, patches, development, and resilience. Its official change list identifies the affected controls and assessment procedures.

Where it came from

NIST explicitly attributes this release to Executive Order 14306. This is a different authority link from FISMA's original instruction to develop the catalog.

What changed—or stayed

The release does not amend FISMA or A-130. The checked change list does not revise SA-9; the discussion above quotes the preserved 2020 catalog. SP 800-53B's release number changed for consistency, with no baseline changes in this release.

NIST guidance

NIST SP 800-53 Release 5.2.0: Summary of Changes

Opening explanation, PDF p. 1; full control change list follows · 2025-08-27

This revision focuses on improving the security and reliability of software updates and patches in response to Executive Order 14306 on strengthening the Nation's cybersecurity. SP 800-53 Release 5.2.0 addresses multiple aspects of the software development and deployment process, including software and system resiliency by design, developer testing, the deployment and

management of updates, and software integrity and validation. This update also revises the discussion sections of some existing controls to provide additional scoping and implementation examples. A detailed list of changes is included below in Table 1.

Read original · PDF 1 Source details Link to quote

SP 800-18 Revision 2 puts data flows into system plans

2026 **NIST guidance**

The June revision combines planning guidance for security, privacy, and cybersecurity supply-chain risk. It says plans should describe the data lifecycle, responsible people, components and flows, and risks from information shared outside the system.

Where it came from

Its executive summary explicitly connects the planning duty to A-130 and its planning activities to SP 800-37. Its authority statement cites FISMA 2014.

What changed—or stayed

The latest planning guide still treats information and systems together without making their boundaries identical. Nonfederal organizations may use this guide voluntarily; a separate legal, policy, or agreement requirement must be identified where its use is compulsory.

NIST guidance

NIST SP 800-18 Revision 2

Executive summary, printed p. 1 · 2026-06-30

System plans collectively refer to the system security plan, system privacy plan, and cybersecurity supply chain risk management (C-SCRM) plan that describe the design and implementation of security, privacy, and cybersecurity supply chain protections throughout the system life cycle. System plans:

• Include information about the data being created, collected, disseminated, used, stored, and disposed of;

• Identify individuals who are responsible for system risk management efforts;

• Describe the environment of operation, system components, and data flows within the environment; and

• Account for risks associated with the sharing of information outside the scope of the system.

Read original · PDF 11 Source details Link to quote

NIST guidance

NIST SP 800-18 Revision 2

Executive summary, printed p. 1; explicit A-130 connection · 2026-06-30

Office of Management and Budget (OMB) Circular A-130 [OMBA-130] requires federal agencies to develop and maintain system plans for managing risks, including implementation details for the controls allocated to address the requirements. Nonfederal organizations may voluntarily apply the guidelines provided in this publication to develop and maintain system plans consistent with their risk management strategies.

Read original · PDF 11 Source details Link to quote

What agencies must do now

Start with the information and the service being acquired. Then identify every applicable duty. The texts do not support a blanket rule that commercial services are outside federal information-system obligations, or that only directly controlled components count.

They do support different requirements in specifically defined nonfederal settings. The clearest example here is CUI confidentiality under 32 CFR 2002.14(h)(2) and SP 800-171. That distinction must be applied with its scope and exceptions intact.

A-130's service scope · Current SP 800-171 scope · The disagreement over a general definition

What must be protected?

Information duty

Information collected or maintained by or on behalf of the agency, with protections proportionate to harm.

System duty

Systems used or operated by the agency or by another organization on its behalf, under the same statutory risk standard.

Read the underlying wording

What does the agency have to do?

Information duty

Assess harm, determine needed protection, implement risk-reducing policies, test controls, and carry applicable security and privacy duties into agreements.

System duty

Include covered systems in the agency program; categorize, select and assess controls, authorize, and monitor under the applicable standards and policy.

Read the underlying wording

What if another organization handles the information?

Information duty

A-130 §4(j)(1) requires suitable terms in lifecycle agreements. Section 4(j)(2) also reaches systems that collect or maintain federal information on behalf of government.

System duty

The same §4(j)(2) covers systems used or operated on behalf of government. Its listed oversight duties include controls, inventory, access, interfaces, and incident response.

Read the underlying wording

What changes for qualifying nonfederal CUI systems?

Information duty

The CUI rule directs confidentiality requirements through SP 800-171, with its exceptions. Requirements apply to relevant components, including components protecting the CUI.

System duty

The CUI rule treats systems operated for the agency as agency systems and allows the agency's additional internal requirements. It explicitly includes outsourced processing for mixed users.

Read the underlying wording

Who accepts the risk?

Information duty

The information owner or steward retains responsibility for appropriate use and protection when information is shared.

System duty

The authorizing official may authorize system operation, common controls, or use of an external system, service, or application.

Read the underlying wording

Does a boundary settle the legal scope?

Information duty

No. Information can leave a system boundary while protection and agreement duties continue.

System duty

No. An external service may be outside one authorization boundary while still subject to applicable controls, assurance, and oversight.

Read the underlying wording

A practical reading order for an agency decision

1. Identify the information, its lifecycle, and any separate privacy, records, confidentiality, or CUI requirements.
2. Determine what the other organization does: collects or maintains information for the agency, operates a system for it, receives information for another purpose, or exchanges information across a boundary. These can overlap.
3. Apply the appropriate policy and standard to that arrangement. Do not substitute “commercial,” “shared,” or “outside our boundary” for the actual scope language.
4. Put the necessary protections, oversight, access, interfaces, incident duties, and evidence requirements into suitable agreements. Categorize and authorize where required.
5. Monitor performance and changing risk. Preserve the information owner’s responsibilities and the agency official’s decision record.

This reading order is this report’s synthesis of 44 USC 3554, A-130 §4(j), SP 800-37’s role descriptions, and SP 800-47’s exchange guidance. It is not an additional rule.

Editions, coverage, and open questions

This is a focused history of information, system, and service responsibilities. It is not an exhaustive inventory of every federal security requirement. Publication dates, later updates, and withdrawal wrappers are kept separate. “Current” below means the final publication checked for this report, not proof that every applicable agency rule has been found.

Law

Checked: PRA 1980/1995; Computer Security Act; GISRA 2000; FISMA 2002/2014; FedRAMP Act 2022

Original enactments quoted. Current-code cross-check uses the existing OLRC release 119-118 through September 30, 2026. No claim that all intervening amendments or later October enactments were exhaustively checked.

A-130

Checked: 1985 origin; 1993, 1996, 2000, 2016

1985 origin is quoted from OMB’s 1993 explanation. Earlier notices and original circulars remain in the main library. The 2016 circular remains the listed current circular checked October 25; not every proposed draft or comment is recovered.

OMB instructions

Checked: 2003, 2004, 2010, 2011, 2013, 2024

Selected instructions establish the relevant interpretation and program changes. The larger site contains the broader memorandum search; this report is not a quote-by-quote comparison of every annual FISMA reporting memorandum.

FIPS

Checked: 199 (2004), 200 (2006)

Both directly quoted. The report distinguishes mandatory standards from supporting NIST guidance. Specialized cryptography and identity FIPS are outside this scope.

SP 800-37

Checked: 2004; Revision 1 original 2010 and June 2014 update; Revision 2 (2018)

Original and updated Revision 1 files compared. Quoted external-service wording is unchanged. Revision 2 is the current final edition checked; drafts do not replace it.

SP 800-53

Checked: 2005; Revisions 1 (2006), 2 (2007), 3 (2009/2010), 4 (2013/2015), 5 (2020); Release 5.2.0 (2025)

SA-9 and its context are compared. Saved Revision 3/4/5 files include later updates. This does not establish the first appearance of every changed word. The 2025 change list is preserved; it does not change SA-9. Intermediate maintenance releases are not reconstructed individually.

SP 800-60

Checked: 2004 and Revision 1 (2008), Volume I

The statutory connection and method are quoted from both editions. The many category-specific mappings in Volume II are outside this report's comparison.

SP 800-171

Checked: 2015 with January 2016 updates; Revision 1 with June 2018 updates; Revision 2 with January 2021 updates; Revision 3 (2024)

Scope, information/system exclusions, agreement triggers, component scoping, and planning are compared. Intermediate corrections are not all separate milestones. Revision 3 is the current final publication checked.

Other NIST guidance

Checked: SP 800-18 Revision 1 (2006) and Revision 2 (2026); SP 800-144 (2011); SP 800-47 Revision 1 (2021)

Selected for boundary, service, exchange, and planning questions. This is not a complete history of every NIST risk, assessment, privacy, or supply-chain publication.

Regulations and public comments

Checked: NARA final rule and responses (2016); DHS final-rule response (2023); OMB 1996 response; NIST 2024 comment analysis

Government responses are quoted in their own context. The full A-130 2015 comment docket was not recovered. The retained EPIC and RAND submissions are examples of comments in the archive, not representative of all commenters or adopted policy.

Research method

Checked: Inforegs original-source archive plus official web publications

Inforegs semantic indexing was complete when checked. Search results guided discovery; quotations were checked against originals. A complete index is not proof that the archive contains every relevant authority. Research and editorial review were self-review, not independent legal review.

Download the edition and coverage ledger · Download authority relationships

Sources and downloads

Original files are preserved with their SHA-256 hashes. The library retains sources from the earlier report so existing source links still work. Retention does not mean the source is quoted in this edition.

Sources JSON · Sources CSV · Quotation text and locations · Milestone source index

Privacy Act, P.L. 93-579

Law · 1974-12-31 · Retained reference

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`e7ee29d2c9d09b077dc356a4583a4a008621dce40b0f23fd51e19b5368815d4a`

Paperwork Reduction Act of 1980

Law · 1980-12-11 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`5af687ae7085e87b72357c4ef3969bfa4388bddb179c76363ec7d49759036299`

- §2, former 44 USC 3504(f)(1); 94 Stat. 2816

A-130: initial circular

OMB circular · 1985-12-12 · Retained reference

Local original · Original publisher

Amended by Transmittals 1–4.

Retrieved 2026-10-10. SHA-256:
`c6c996a0a79cfbae6c9220153a4d019871ee22bf0930fd180c70055cffe7b784`

Computer Security Act of 1987, P.L. 100-235

Law · 1988-01-08 · 2 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`2eb2c0cdd6d2bbf652b358266e98be07fdb2b52526554aded1f90bb0a5238fd0`

- §3, NBS Act §20(d)(2)(A); 101 Stat. 1726
- §3, NBS Act §20(a)(4); 101 Stat. 1725

A-130: Transmittal 1

OMB policy · 1993-06-25 · 2 quotations

Local original · Original publisher

Historical amendment; later editions contain further changes.

Retrieved 2026-10-10. SHA-256:
`b394b7885e2a250a20af528c2c032bc8a749987bc7346c0f3bf385f00b05e270`

- 1993 notice, Background (opening explanation)
- Appendix IV §3, analysis of §6: Government Information

Paperwork Reduction Act of 1995

Law · 1995-05-22 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`364b71f86413ba4424bba70125e51c983ea77d6c7d2d7aa7e62377520daddda9`

- §2, 44 USC 3506(g); 109 Stat. 175

A-130: Transmittal 3

OMB policy · 1996-02-08 · 1 quotation

Local original · Original publisher

Historical consolidated text; amended in 2000 and replaced in 2016.

Retrieved 2026-10-10. SHA-256:
`906a73bd9b77740b0ed2bfc6f2201ec33363e2a04def3f3108fc7aecc146c4b6`

- §8(a)(1)(g)

Clinger–Cohen Act in P.L. 104-106

Law · 1996-02-10 · Retained reference

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`60ecc3db67b9a71474f8e11cb310d1d86f8246fc9df154b31f93801dbe786c7e`

A-130 Transmittal 3: Federal Register final notice

OMB circular · 1996-02-20 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`86aae370d573c8d3e7aebddc8b629eda764043768bee8835f9bb8cccc4a5f0c5`

- 61 FR 6430, response to comment 5; explanation, not a separate rule

GISRA in P.L. 106-398

Law · 2000-10-30 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`931a74e24e0288af43250e5e5d32c5c456c119904c08a6da4d87cb2adc0e41f8`

- §1061, former 44 USC 3534(a)(1); 114 Stat. 1654A–268

A-130: Transmittal 4 consolidated circular

OMB policy · 2000-11-28 · Retained reference

Local original · Original publisher

Replaced by 2016 A-130; PDF contains main circular, appendices listed separately.

Retrieved 2026-10-10. SHA-256:
`51408f42212316a9e92c2b4ed3bfe4299768afd150280322096ed97e8caccb82`

A-130 (2000), Appendix III

OMB policy · 2000-11-28 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`9b2406bfb6d36800fea1c38a361b17819c2adab4e45b5c4d14070ae512f29a74`

- Appendix III, Part B, General Support Systems, Security Plan / Interconnection

---

A-130 (2000), Appendix IV

OMB circular · 2000-11-28 · Retained reference

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`dec37813f1c79ee93e2cf259690af4243f274a6f4643bcdbe6b283d3692a5ca3`

Transmittal 4 final Federal Register notice

OMB circular · 2000-12-12 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`88f92a0f399e62699c4f7693ea262c4a0d87cb32aff430e9d8fbc8993c5cd1f9`

- 65 FR 77677, summary; November 28 revision announced December 12

Homeland Security Act of 2002, Title X

Law · 2002-11-25 · Retained reference

Local original · Original publisher

General effective date 60 days after enactment; compare the December 17 E-Government Act separately.

Retrieved 2026-10-10. SHA-256:
`e96e8b44905469d308187a78a906db5695ebb0b3c218575e55835c62526a0fd2`

E-Government Act / FISMA 2002

Law · 2002-12-17 · 6 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`1eec72dc1f004c04be63c78eb850321592881cbf10bca889301f109dc5c9650e`

- §301, former 44 USC 3544(a)(1)(A); 116 Stat. 2949
- §301, former 44 USC 3544(b); 116 Stat. 2950
- §303, NIST Act §20(a)(2)–(3); 116 Stat. 2957
- §303, NIST Act §20(c)(3)–(4); 116 Stat. 2958
- §303, NIST Act §20(b)(1)(A)–(B); 116 Stat. 2957; minimum requirements follow in (C)
- §302, 40 USC 11331(b)(2); 116 Stat. 2956

M-03-19, Reporting Instructions for the Federal Information Security Management Act and Updated Guidance on Quarterly IT Security Reporting

OMB memorandum · 2003-08-06 · 1 quotation

Local original · Original publisher

Rescinded by M-17-26, Eliminated – Information Technology.

Retrieved 2026-10-10. SHA-256:
`5309251f1fd6afcdf11c9d183bc29c998ca86a0cfa0b84898db8369f7c8e9815`

- §I.A, p. 5

FIPS 199: Security Categorization

Mandatory standard · 2004-02-01 · 2 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`73d19f05f71e30f378050f178aa3943c38790bbae56c07f2b5708c5a1a90242f`

- §1, printed p. 1
- §2, printed p. 1

SP 800-37: Certification and Accreditation

NIST guidance · 2004-05-01 · 2 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`97f1674500dab05be7fc48c0ef7d90eb44d32bc7c88212dfc9ec27af1add0522`

- Authority, p. ii
- Executive summary, p. v; explicit A-130 Appendix III requirement

SP 800-60 Vol. 1 — Guide for Mapping Types of Information and Information Systems to Security Categories

NIST guidance · 2004-06-10 · 1 quotation

Local original · Original publisher

Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/60/v1/final; DOI: https://doi.org/10.6028/NIST.SP.800-60ver2v1; PDF/publication URL: https://doi.org/10.6028/NIST.SP.800-60ver2v1; CSRC local download link: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-60ver2v1.pdf

Retrieved 2026-10-13. SHA-256:
`d0b1f1c6e45e89791a0d50f752de80a42a72a2ccac6075a5ef8284c396597e2e`

- Volume I, executive summary, p. vii

M-04-25, FY 2004 Reporting Instructions for the Federal Information Security Management Act

OMB memorandum · 2004-08-23 · 1 quotation

Local original · Original publisher

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`6e89e7950cae63ee7ca425e55b60061f30f011f1850173681e06dbfd9a8a344b`

- §II.A, p. 5; historical reporting guidance

SP 800-53: Recommended Security Controls

NIST guidance · 2005-02-01 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`5fd3ea2a25d0c85038583b465896738dd952a33f52698a01a07d456a1eb54e2b`

- SA-9, control and opening supplemental guidance; p. 92

SP 800-18 Rev. 1: Security Plans

NIST guidance · 2006-02-01 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`1635870f7cac9c0606cddbf42a7e4d0d8d01c5ab8709d3667821a4cdeaddd506`

- §2.1, printed p. 9; see footnote 10 on budgetary/programmatic/operational authority

FIPS 200: Minimum Security Requirements

Mandatory standard · 2006-03-09 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`107a9b9cdc8eccf37386aec28bbaf2dfaef5cfece17151ceabc3960423243a57`

- §4, printed p. 4; footnote 5 requires the current SP 800-53, as amended

SP 800-53 Rev. 1 — Recommended Security Controls for Federal Information Systems

NIST guidance · 2006-12-19 · 1 quotation

Local original · Original publisher

Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/53/r1/final; DOI: https://doi.org/10.6028/NIST.SP.800-53r1; PDF/publication URL: https://doi.org/10.6028/NIST.SP.800-53r1; CSRC local download link: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-53r1.pdf

Retrieved 2026-10-13. SHA-256:
`819365c6479f889137ea21ff3e25478dd35e5d8ddaa190b16b4db19021c1d0c0`

- SA-9 supplemental guidance, p. 120

SP 800-53 Rev. 2 — Recommended Security Controls for Federal Information Systems

NIST guidance · 2007-12-19 · 1 quotation

Local original · Original publisher

Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/53/r2/final; DOI: https://doi.org/10.6028/NIST.SP.800-53r2; PDF/publication URL: https://doi.org/10.6028/NIST.SP.800-53r2; CSRC local download link: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-53r2.pdf

Retrieved 2026-10-13. SHA-256:
`ec703bd3a2d5b85528c3b5f74d8b1a10f02d869b086c4103ba622078f2634d5b`

- SA-9 supplemental guidance; PDF p. 130 including archive cover

SP 800-60 Vol. 1 Rev. 1 — Guide for Mapping Types of Information and Information Systems to Security Categories

NIST guidance · 2008-08-01 · 1 quotation

Local original · Original publisher

Original located through Inforegs; copied and SHA-256 checked 2026-10-25. final. CSRC record: https://csrc.nist.gov/pubs/sp/800/60/v1/r1/final; DOI: https://doi.org/10.6028/NIST.SP.800-60v1r1; PDF/publication URL: https://doi.org/10.6028/NIST.SP.800-60v1r1; CSRC local download link: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-60v1r1.pdf

Retrieved 2026-10-13. SHA-256:
`6f13f57f11697efcba694d0c9935c99168512f737cc76f2c432f248550128460`

- Volume I Revision 1, executive summary, p. vii

SP 800-53 Rev. 3 — Recommended Security Controls for Federal Information Systems and Organizations

NIST guidance · 2009; updated August 2010 · 1 quotation

Local original · Original publisher

Saved Revision 3 includes August 2010 updates and an archive cover. Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/53/r3/upd2/final; No download or DOI link exposed on the CSRC detail page.; DOI metadata verified against Crossref/NIST record title (similarity 1.00): https://doi.org/10.6028/nist.sp.800-53r3

Retrieved 2026-10-13. SHA-256:
`772a0b23cbc8d11a9a5ff77494d7bffe3a495dfbcfef3a507e29726bd4826e2f`

- SA-9 control; PDF p. 176 including archive cover

SP 800-37 Rev. 1 — Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach

NIST guidance · 2010-02-22 · 1 quotation

Local original · Original publisher

Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/37/r1/final; CSRC local download link: https://csrc.nist.gov/files/pubs/sp/800/37/r1/final/docs/sp800-37-rev1-final.pdf

Retrieved 2026-10-13. SHA-256:
`685fe443c868692c43054c074ac329db41f3910489204e39217eacb402520f4d`

- §2.4, printed p. 15; Appendix I referenced here is in SP 800-53

M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management

OMB policy · 2010-04-21 · 3 quotations

Local original · Original publisher

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`de73191abda2c3037a37d6ff60566a6dd72c9aacbeaa8f5337b1f7be467273d2`

- FY2010 reporting instructions, question 36, printed p. 13
- Question 36, printed p. 14
- Question 38, service providers, printed p. 15; historical 2010 instructions

NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments

Guidance · 2010-09-08 · 1 quotation

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`c617280c8662418efa5fc3aeb4ac57e31edf64e062ce8eec016bf361875be094`

- NARA Bulletin 2010-05, question 6

SP 800-145: The NIST Definition of Cloud Computing

NIST guidance · 2011-09-01 · Retained reference

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`7b0c1a9fdfc67218b8ba2098f448c100c27070db91736b3c87fed63bfa21d418`

SP 800-144: Security and Privacy in Public Cloud Computing

NIST guidance · 2011-12-01 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`47f0fdf31f4f2b37fb2a8fa0bf77235aad0b3daa74a6397603a619a839500a42`

- §6, Conclusion, printed p. 52

Security Authorization of Information Systems in Cloud Computing Environments

OMB policy · 2011-12-08 · 1 quotation

Local original · Original publisher

Rescinded by M-24-15 (opening and concluding sections).

Retrieved 2026-10-10. SHA-256:
`1000dc126873b7d4831512434a5087d6991e7b02f73200a39d49e683ec068fbc`

- §3(a), printed p. 2; read with §3(b)–(c) and private-cloud exception in footnote 4

M-14-03, Enhancing the Security of Federal Information and Information Systems

OMB memorandum · 2013-11-18 · 1 quotation

Local original · Original publisher

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`a48fae52553832b7ce8884cf77f273d47a7aac309878df87a220ee0a074e9761`

- p. 2, action 1; ISCM means information security continuous monitoring

SP 800-53 Rev. 4: Security and Privacy Controls

NIST guidance · 2013; updated January 2015 · 1 quotation

Local original · Original publisher

Saved Revision 4 includes January 22, 2015 updates. Withdrawn September 23, 2021, superseded by Rev. 5; withdrawal recorded on the archived PDF cover.

Retrieved 2026-10-10. SHA-256:
`e6f8a1aae41168f4ec9edc5b34aee0a21f2c888c78bf1de33e6ec63a0209db4e`

- Revision 4, SA-9 supplemental guidance, p. F-162; saved edition includes January 22, 2015 update

SP 800-37 Rev. 1 — Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach

NIST guidance · 2014-06-05 · 1 quotation

Local original · Original publisher

June 2014 updated edition, distinct from original February 2010 edition; later withdrawal wrapper included. Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/37/r1/upd1/final; DOI: https://doi.org/10.6028/NIST.SP.800-37r1; PDF/publication URL: https://doi.org/10.6028/NIST.SP.800-37r1; CSRC local download link: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r1.pdf

Retrieved 2026-10-13. SHA-256:
`cd4af4a51c9b016b73116bc5fdfb284f9734e47b9cb95027f9d5d4fe35e74198`

- §2.4, printed p. 15; June 5, 2014 update, archive wrapper included

Federal Information Security Modernization Act

Law · 2014-12-18 · 3 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`96ab24c78d410963ebb0bcd519dbe4b95ee800400c49ea4448e6d3f39c3eb917`

- §2, 44 USC 3554(a)(1)(A); 128 Stat. 3078
- 44 USC 3554(a)(2); 128 Stat. 3078
- 44 USC 3554(b); 128 Stat. 3079

Request for Comments on Circular No. A-130, Managing Information as a Strategic Resource

Notice · 2015-10-22 · Retained reference

Local original · Original publisher

Official issuing or archival host

Retrieved 2026-10-23. SHA-256:
`60ad864505a08346fbe8ce1da82c748210a4f0ba61a64da2f46501cee090b588`

Comments of the Electronic Privacy Information Center to OMB on Circular No. A-130

Public comment · 2015-12-04 · Retained reference

Local original · Original publisher

Primary commenter-hosted submission

Retrieved 2026-10-23. SHA-256:
`3b51b3a36fd035b9d923adc163b73c043961d022bc85700e9406ce26a02da114`

SP 800-171: Protecting CUI in Nonfederal Systems

NIST guidance · 2015; updated January 2016 · 3 quotations

Local original · Original publisher

Saved original publication includes January 2016 updates. Historical edition

Retrieved 2026-10-10. SHA-256:
`0cf9452bccca2eea7d5dd4283d3daf62f58b9663be35ceceb62c49aa3dd02f0d`

- §1.1, printed p. 2; June 2015 text, saved PDF includes January 2016 update
- §1.1 footnote 8, printed p. 2
- §1.1, printed p. 3

A-130: Managing Information as a Strategic Resource

OMB policy · 2016-07-28 · 7 quotations

Local original · Original publisher

2016 revision; later laws and memoranda also apply.

Retrieved 2026-10-10. SHA-256:
`f1a2e73a1063eab7d83da2a3bfa810f3aaebc9a6ef8e9d264ffc57ccd02152e6`

- §10(a)(22)–(23), printed p. 29
- Appendix I §4(j)(1), printed p. 14
- Appendix I §4(j)(2)(a)–(d), printed p. 14
- Appendix I §4(j)(2)(e)–(f), printed p. 14
- Appendix I §5(r), printed p. 25
- Appendix I §5(r), printed p. 26
- Appendix I §4(d)(1), printed p. 7

A-130 2016 final notice

OMB circular · 2016-07-28 · Retained reference

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`d7d35c2d1635f604b9e68594a710258ff21568c8477c0fb627744e36bd358939`

NARA CUI final rule and comment responses

Regulation · 2016-09-14 · 3 quotations

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`f3e00594bf25f429b30f881900f3bec0fff2b70001d0b152902eb4b58fdc0a4f`

- 32 CFR 2002.14(h)(1), 81 FR 63341; final rule effective November 14, 2016
- 32 CFR 2002.14(h)(2), 81 FR 63341; quoted with both exceptions
- 81 FR 63326, response on §2002.1 scope; agency explanation

SP 800-171 Rev. 1 — Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

NIST guidance · 2016; updated June 2018 · 2 quotations

Local original · Original publisher

Saved Revision 1 includes June 7, 2018 updates and a later withdrawal cover. Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/171/r1/upd3/final; DOI: https://doi.org/10.6028/NIST.SP.800-171r1; PDF/publication URL: https://doi.org/10.6028/NIST.SP.800-171r1; CSRC local download link: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171r1.pdf

Retrieved 2026-10-13. SHA-256:
`ba5afc608fc94baeda05c53ccd5d63dc44071f7042dfcf8bdf04b3b75485310d`

- §1.1, printed p. 2; Revision 1 December 2016, saved edition updated June 7, 2018
- §3.12.4, printed p. 14; footnote 26 does not prescribe a plan format

RAND comments on DHS safeguarding proposal

Public comment · 2017-03-23 · Retained reference

Local original · Original publisher

Original acquired by inforegs from Regulations.gov; SHA-256 verified. Direct retrieval October 24 returned 403.

Retrieved 2026-10-23. SHA-256:
`b94bb7c8a4cfc506c67606cded3fb6ee7dca00598268f06e5fb47c14ed17ee97`

SP 800-37 Rev. 2: Security and Privacy RMF

NIST guidance · 2018-12-20 · 4 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`4f75e1136bb905a654f1bcd9eefefb4108f47597276ee5eec0688f6d96f6a01d`

- Appendix D, Information Owner or Steward, printed p. 119
- Appendix D, Authorizing Official, printed p. 114
- Appendix G, printed p. 159
- Appendix G, printed p. 160; an alternative risk response, not a waiver of law

SP 800-53 Rev. 5: Security and Privacy Controls

NIST guidance · 2020; updated December 2020 · 1 quotation

Local original · Original publisher

Saved Revision 5 includes December 10, 2020 updates; 2025 release change list is separately preserved. Historical edition

Retrieved 2026-10-10. SHA-256:
`fc63bcd61715d0181dd8e85998b1e6201ae3515fc6626102101cab1841e11ec6`

- Revision 5, SA-9 control and discussion; September 2020, includes December 10, 2020 updates

SP 800-171 Rev. 2 — Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

NIST guidance · 2020; updated January 2021 · 2 quotations

Local original · Original publisher

Saved Revision 2 includes January 28, 2021 updates and a later withdrawal cover. Original located through Inforegs; copied and SHA-256 checked 2026-10-25. withdrawn. CSRC record: https://csrc.nist.gov/pubs/sp/800/171/r2/final; No download or DOI link exposed on the CSRC detail page.; DOI metadata verified against Crossref/NIST record title (similarity 1.00): https://doi.org/10.6028/nist.sp.800-171r2

Retrieved 2026-10-13. SHA-256:
`298bdbfcf6a4890a564b225c893230a0b32b2e69e3b98dd898aaeb1d544c5e12`

- Revision 2, front matter p. vii; February 2020, includes January 28, 2021 updates
- §1.1, printed p. 2

NIST SP 800-47 Revision 1

NIST guidance · 2021-07-20 · 2 quotations

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`3ba5248bab614da212440a1bcfe814f0068ef95ebc2d73025742bc78a89c865a`

- §1, printed p. 1
- §1.1, printed p. 1

FAR 52.204-21, November 2021 clause; FAC 2026-01

Regulation · 2021-11 · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`da2a7d9150526fabb12e1869ebd82592b7fdebb1e01dd8081d93d401d6e4534d`

FedRAMP Authorization Act in P.L. 117-263

Law · 2022-12-23 · 4 quotations

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`9e5d37dfa7d1282073c16f3dde21978078f62f58f9db36f4828e270e02de933f`

- §5921, 44 USC 3607(b)(3); 136 Stat. 3449
- 44 USC 3608; 136 Stat. 3450
- 44 USC 3614(1); 136 Stat. 3454
- 44 USC 3613(e)(2); 136 Stat. 3454

DHS safeguarding final rule and comment responses

Regulation · 2023-06-21 · 1 quotation

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`a5b720fb0fd7297d3756086f4e979a98060d8f8cefb74866aec6bd403ebb9fd5`

- 88 FR 40571, response under definition of Federal information system; DHS explanation

---

5 USC 552 — FOIA

Law · 2024 Code edition · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`b1fad0a21337dc814f2f05e47f260dba90752af9f72c66c7b0323477183323de`

44 USC 3301 — Federal records

Law · 2024 Code edition · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`ff9de8a95c4847cd61e115e1863f0a86fb766e66ffa29faae43bbb42623cb1ec`

NIST — NIST SP 800-171 Revision 3 Final Public Draft and SP 800-171A Revision 3 Initial Public Draft: Analysis of Comments Received

NIST guidance · 2024-02-21 · Retained reference

Local original · Original publisher

Original located through Inforegs; copied and SHA-256 checked 2026-10-25. published analysis. Candidate pending topic relevance; NIST staff analysis of FPD/IPD submissions; explanatory/adjudication record, not binding. Screen specifically for scope/on-behalf comments and NIST disposition.

Retrieved 2026-10-23. SHA-256:
`132967ff206730d3bf01318a547738bf3589e157ee950cc90b68bd3f62840a8d`

SP 800-171 Rev. 3: Protecting CUI

NIST guidance · 2024-05-14 · 1 quotation

Local original · Original publisher

Historical edition

Retrieved 2026-10-10. SHA-256:
`3e4631df8b5d61f40a6e542b52779ef30ddbbfff31e09214fa94ad6e6f5e6d08`

- Revision 3 §1.1, printed p. 2; read with footnote 8 on FISMA

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

OMB policy · 2024-07-25 · 3 quotations

Local original · Original publisher

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`07aabe7fd0baa34e3c77b7c9537204c6ac1caff473e04af8dc7e40743c30250a`

- §III, printed p. 5; exclusions immediately follow
- §IV footnote 7, printed p. 6
- §III, exclusions 1–6, printed p. 5; footnote 6 limits scope to unclassified, non-national-security systems

32 CFR Part 2002: Controlled Unclassified Information (2025 edition)

Regulation · 2025 · Retained reference

Local original · Original publisher

official host

Retrieved 2026-10-23. SHA-256:
`7613256287fea6dadc38f7279cb2c63c377f808295e70fa9785660651236958a`

NIST SP 800-53 Release 5.2.0: Summary of Changes

NIST guidance · 2025-08-27 · 1 quotation

Local original · Original publisher

Official NIST change list; retrieved using curl after urllib received HTTP 403.

Retrieved 2026-10-25. SHA-256:
`bc4e626745fa4cf48a1bb6d09f552aa4f7a4b945b459119407d08f2e97a89a86`

- Opening explanation, PDF p. 1; full control change list follows

NIST SP 800-18 Revision 2

NIST guidance · 2026-06-30 · 2 quotations

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`640f9124469f285fc39dbeffd59708c84043d1a6b64cc87988f31e7e98942371`

- Executive summary, printed p. 1
- Executive summary, printed p. 1; explicit A-130 connection

NIST publication status: SP 800-171 Revision 3

Publication status · 2026-10-24 · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`a3cdded2f973b252b68e2082f794626a425c9bdbbf31ce7afb4a8ff1d90bf595`

NIST publication status: SP 800-18 Revision 2

Publication status · 2026-10-24 · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`6e9b69244d8347df4a1b6c2a70ba411afbafd55c14ea748e420c6279501878a6`

NIST publication status: SP 800-37 Revision 2

Publication status · 2026-10-24 · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`9467380090171f006bbd1db9525f5f4df92ec6181081f9c80bb9d77aa68a9fc2`

NIST publication status: SP 800-53 Revision 5 / Release 5.2.0

Publication status · 2026-10-24 · Retained reference

Local original · Original publisher

Preserved original; extracted text is a reading aid.

Retrieved 2026-10-24. SHA-256:
`00c4e550ba1326976657136497711dc3f4dffc86e90f0d71052a3ebdc1b4d21c`

FedRAMP scope guidance, retrieved October 24, 2026

Program guidance · Retrieved 2026-10-24 · Retained reference

Local original · Original publisher

Official FedRAMP/2026 repository, default branch snapshot. Retrieval date is not issuance date.

Retrieved 2026-10-24. SHA-256:
`a338ad564d8c1eb0a6929e79df24d864bb214e66e12e54a2ae708ef18a9e26f7`

FedRAMP 2026: content/scope.md

Program guidance · Snapshot 2026-10-13 · Retained reference

Local original · Original publisher

Official FedRAMP GitHub repository, commit 97fc5d845b51c186d2e7fc232ba78b77000e65a3

Retrieved 2026-10-13. SHA-256:
`a338ad564d8c1eb0a6929e79df24d864bb214e66e12e54a2ae708ef18a9e26f7`

---

44 USC 3502 — Definitions

Law · Through 2026-09-30 · Retained reference

Local original · Original publisher

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

44 USC 3506 — Federal agency responsibilities

Law · Through 2026-09-30 · Retained reference

Local original · Original publisher

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

44 USC 3554 — Federal agency responsibilities

Law · Through 2026-09-30 · Retained reference

Local original · Original publisher

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

44 USC 3614 — Roles and responsibilities of the Office of Management and Budget

Law · Through 2026-09-30 · Retained reference

Local original · Original publisher

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

5 USC 552a — Records maintained on individuals

Law · Through 2026-09-30 · Retained reference

Local original · Original publisher

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`f8e6aa5def8854f8d2b1702eccd36962b92080d6212b64c543fa72f1ae1b209a`

Back to top · Interactive edition

Historical sources and current guidance, with the report's interpretation identified separately.